

DIPLOMARBEIT

Konzeption einer Verwaltungsapplikation für den Polizeisportverein

Ausgeführt im Schuljahr 2025/26 von:

Barsam Aghajani Rizi, 5AHIF-01

Betreuer/Betreuerin:

DI Martin Weixlbaum
DI (FH) Franz Reichel

St.Pölten, am 26. Juli 2026

Zusammenfassung

Implementierung für den Polizeisportverein:

Im Rahmen dieser Diplomarbeit wurde eine Verwaltungsapplikation für den Polizeisportverein entwickelt. Ausgangspunkt des Projekts war die bestehende Verwaltung von rund 3000 Mitgliedern über eine Access-Datenbank sowie analoge Prozesse wie physische Mitgliedsausweise und klassische Zahlungsabwicklungen. Ziel war es, diese Abläufe zu digitalisieren und eine moderne, benutzerfreundliche Lösung bereitzustellen.

Die entwickelte Applikation ermöglicht die digitale Verwaltung von Mitgliedsdaten sowie deren selbstständige Pflege durch die Nutzer. Ein zentraler Bestandteil ist der digitale Mitgliedsausweis, welcher den Mitgliederstatus sicher und jederzeit nachweisbar macht. Darüber hinaus bietet die App Funktionen wie Erinnerungen über einen integrierten Kalender, Push-Benachrichtigungen für Neuigkeiten und Termine sowie einen Sponsorenbereich zur Präsentation von Partnern des Vereins.

Die Umsetzung der Anwendung erfolgte mithilfe des Frameworks Flutter für die Entwicklung der Benutzeroberfläche. Für die serverseitige Logik wurde ein Backend mit Spring realisiert, während PostgreSQL als Datenbank zur strukturierten Speicherung der Mitgliedsdaten eingesetzt wird. Diese Architektur ermöglicht eine skalierbare und performante Lösung.

Übersicht über die Diplomarbeit:

Neben der praktischen Umsetzung behandelt die Diplomarbeit grundlegende Aspekte der Softwareentwicklung. Dazu zählen unter anderem die Qualitätssicherung durch verschiedene Testmethoden, die Umsetzung von Barrierefreiheit gemäß gesetzlichen Vorgaben sowie die Entwicklung eines responsiven und benutzerfreundlichen Designs.

Abstract

Implementation for the Police Sports Association: :

As part of this diploma thesis, a management application for the Police Sports Association was developed. The starting point of the project was the existing administration of around 3,000 members using an Access database, as well as analog processes such as physical membership cards and traditional payment handling. The goal was to digitize these processes and provide a modern, user-friendly solution.

The developed application enables the digital management of member data as well as self-service updates by users. A central component is the digital membership card, which allows members to securely verify their status at any time. In addition, the app offers features such as reminders via an integrated calendar, push notifications for news and events, and a sponsor section for presenting the association's partners.

The application was implemented using the Flutter framework for the user interface. The server-side logic was developed with a Spring-based backend, while PostgreSQL was used as the database for structured storage of member data. This architecture enables a scalable and high-performance solution.

Overview on the diploma thesis:

In addition to the practical implementation, the diploma thesis also covers fundamental aspects of software development. These include quality assurance through various testing methods, the implementation of accessibility in accordance with legal requirements, and the development of a responsive and user-friendly design.

Inhaltsverzeichnis

Zusammenfassung	3
Abstract	5
Inhaltsverzeichnis	7
1 Einleitung	1
1.1 Einleitung Barsam Aghajani Rizi	1
1.1.1 Zielsetzung der Arbeit	2
1.1.2 Abgrenzung und Umfang	3
1.1.3 Bedeutung der Arbeit im größeren Kontext	3
1.2 Einleitung Christian Langsteiner	4
1.2.1 Überblick und Problemstellung	4
1.2.2 Relevanz des Themas	5
1.2.3 Zielsetzung und Forschungsfragen	5
1.2.4 Methodik und Aufbau der Arbeit	6
1.2.5 Abgrenzung und Zielgruppe	7
1.2.6 Aufbau der Arbeit	7
1.3 Einleitung David Steininger	7
1.3.1 Problemstellung und Relevanz der Thematik	8

1.3.2	Zielsetzung und Forschungsfragen	8
1.3.3	Aufbau der Arbeit	9
1.3.4	Methodisches Vorgehen	9
1.4	Einleitung Nadine Pöll	10
1.4.1	Ziele und Aufbau	10
1.4.2	Qualitätssicherung in Softwareprojekten	10
1.4.3	Herausforderungen der Softwarequalität	11

2 Identitätsmanagement im digitalen Raum 13

2.1	Was ist digitale Identität?	13
2.1.1	Die vier Kernprozesse des IAM	13
2.1.2	Single Sign-On (SSO)	14
2.2	OAuth 2.0 – Autorisierung	15
2.2.1	Die 4 Rollen	15
2.2.2	Was ist der Authorization Code Flow?	16
2.2.3	Wie funktioniert der Authorization Code Flow?	17
2.3	OpenID Connect – Authentifizierung	19
2.3.1	Identity Token	19
2.3.2	JWT – JSON Web Token	19
2.3.3	Refresh Token	20
2.3.4	PKCE	20

3 ID Austria 21

3.1	Authentifizierungsfaktoren	22
3.2	eIDAS Authentifizierungslevel	22

3.2.1	Authentifizierungslevel	23
3.2.2	Signaturstufen	23
3.3	SAML2 vs. OIDC	24
3.4	Registrierung als Service Provider	24
3.5	Anmeldung mit ID Austria via OIDC	28
3.6	Vorteile der ID Austria Integration im Vereinskontext	31
4	Analyse und Stakeholder	33
4.1	Zielgruppen und Stakeholder	33
4.1.1	Zielgruppen	33
	Administratoren	33
	Mitglieder	34
	Externe Veranstalter	34
4.1.2	Stakeholder	34
4.1.3	Abgeleitete Anforderungen	35
4.2	Use Cases	35
4.2.1	Use Case 1 – Konzeptionelle Registrierung mit ID Austria . . .	36
4.2.2	Use Case 2 – Konzeptionelle Anmeldung mit ID Austria	38
4.2.3	Use Case 3 – Konzeptionelle digitale Signatur mit ID Austria .	39
4.2.4	Use Case 4 – Kalender und Veranstaltungen	39
4.2.5	Use Case 5 – Zahlungsabwicklung	40
4.3	Sicherheitsanforderungen	41
4.4	Datenschutz und DSGVO	42
5	Architektur und Implementierung	45

5.1	Systemarchitektur	45
5.2	Datenbankmodell	46
	Gruppe 1 – Benutzerverwaltung	46
	Gruppe 2 – Vereinsaktivität	47
	Gruppe 3 – Logging und Audit	48
5.3	Authentifizierung	50
5.3.1	Passwort-Hashing mit Salt	50
5.3.2	JWT-Generierung	50
5.3.3	JWT Service	50
5.3.4	Security Config	52
5.4	Rollenbasierter Zugriff	53
5.4.1	Admin-Flags im JWT	53
5.4.2	Fallbeispiel: Mitgliedsausweis abrufen	54
5.5	Geplante ID Austria Integration	55
5.5.1	Authentifizierung	55
5.5.2	User-Model	55
5.5.3	JWT	56
5.5.4	Sicherheitsvorteile	56
6	Fazit	57
6.1	Fazit Barsam Aghajani Rizi	57
6.2	Fazit Christian Langsteiner	58
	Anhang	59
	Abbildungsverzeichnis	59

Tabellenverzeichnis	63
Verzeichnis der Listings	65
Literaturverzeichnis	89
Diplomarbeitsdokumentation	89
Kapitelzuordnung	92
Stundenaufzeichnung	92

Kapitel 1

Einleitung

In diesem Kapitel sind die Einleitungen der jeweiligen Projektmitglieder festgeschrieben.

1.1 Einleitung Barsam Aghajani Rizi

Der Polzeisportverein Sankt Pölten verwaltet seine Mitglieder bis heute größtenteils per Hand. Formulare auf Papier, manueller Zahlungsabgleich, händisch gedruckte Mitgliedsausweise. Damit das alles in der digitalen Welt sicher funktionieren kann, muss jede Person im Internet identifiziert werden können. Auch für Vereine ist dieser Wandel spürbar. Immer mehr Vereine versuchen Abläufe, wie Mitgliederverwaltung, Zahlungsverwaltung, oder Organisation zu digitalisieren. Mit dieser neuen Entwicklung stellt sich die Frage, wie man private Daten schützt, wie man sicherstellt, dass nur berechtigte Personen sich anmelden, und wie man moderne Technologie einsetzen kann.

Gerade bei einem Polzeisportverein, der viele Mitglieder aus unterschiedlichen Bereichen, aber vor allem viele Mitglieder der Polizei betreut, spielt die Datensicherheit der Nutzer eine sehr große Rolle. Im Vordergrund stehen dabei Sicherheit und Vertrauen in die Verarbeitung personenbezogener Daten. Wenn solche Daten, wie Namen, Geburtsdaten, oder Zahlungsdaten verarbeitet werden, muss sichergestellt werden, dass die Daten geschützt bleiben, und nur von befugten Personen eingesehen werden können.

In der Vergangenheit war es üblich eine Benutzername-Passwort-Kombination zu verwenden, um sich einzuloggen. Diese Methode wird allerdings von vielen als unsicher empfunden, da Menschen oft unsichere Passwörter verwenden oder dieselben Pass-

wörter mehrfach verwenden. Dies erleichtert Angreifern den unbefugten Zugriff, etwa durch gestohlene Zugangsdaten aus Datenlecks. Um diese Probleme zu vermeiden, setzen moderne Anwendungen auf sichere Verfahren zur digitalen Identifikation.

Ein wichtiger Schritt in der österreichischen Digitalsicherheit war die Einführung von ID Austria. Eine offizielle, vom Staat bereitgestellte Identität, mit der man sich im Internet ausweisen kann, ähnlich wie mit einem Ausweis in der echten Welt. Die Idee, ID Austria in eine Vereinsapp zu integrieren, entstand aus der Motivation, Sicherheit, Benutzerfreundlichkeit und staatlich geprüfte Technologien miteinander zu verbinden. So wird demonstriert, dass auch kleine Organisationen, wie ein Polzeisportverein, von nationalen digitalen Lösungen profitieren können. Ziel dieser Arbeit ist es, zu zeigen, wie ein Polzeisportverein durch den Einsatz von ID Austria seine Vereinsverwaltung sicherer und moderner gestalten kann.

1.1.1 Zielsetzung der Arbeit

Die vorliegende Diplomarbeit soll aufzeigen, wie ID Austria als sichere Authentifizierungsmöglichkeit in einer mobilen Vereinsanwendung Verwendung finden könnte. An einem konkreten Beispiel, einer App für den Polzeisportverein, wird untersucht, welchen Nutzen eine staatlich geprüfte elektronische Identitätslösung hinsichtlich erhöhter Sicherheit, Datenschutz und Benutzerfreundlichkeit bringen kann. Die Motivation zur Bearbeitung dieses Themas ergibt sich aus der Notwendigkeit, bisher weitestgehend manuelle Vereinsabläufe zu digitalisieren und dabei gleichzeitig sensible personenbezogene Daten besonders sicher zu verwahren.

Ein weiteres Ziel der Arbeit ist es, die theoretischen und technischen Grundlagen des digitalen Identitätsmanagements darzustellen. Dazu werden zentrale Konzepte wie digitale Identität, Identity and Access Management, Single Sign-On sowie die Protokolle OAuth 2.0 und OpenID Connect behandelt, da diese die Grundlage moderner Authentifizierungsverfahren und auch der Einordnung von ID Austria bilden.

Auf dieser Grundlage werden die Anforderungen an eine sichere Vereins-App betrachtet. Hierbei stehen die Zielgruppen und Stakeholder des Systems, zentrale Anwendungsfälle wie Registrierung, Anmeldung, Signatur, Kalender, Zahlungsabwicklung und die sich daraus ableitenden Sicherheits- und Datenschutzanforderungen im Vordergrund. Somit soll gezeigt werden, welche fachlichen und technischen Voraussetzungen eine solche Anwendung erfüllen muss.

Zusätzlich verfolgt die Arbeit das Ziel, die bestehende Systemarchitektur und Implementierung der entwickelten Vereins-App nachvollziehbar darzustellen. Beschrieben werden insbesondere die Architektur der Anwendung, das Datenbankmodell, die aktu-

ell umgesetzte Authentifizierung, die JWT-basierte Zugriffskontrolle sowie der rollenbasierte Zugriff. Dadurch wird die technische Grundlage aufgezeigt, auf der eine sichere Identitätslösung in das System eingebettet werden kann.

Im Rahmen der praktischen Umsetzung konnte die vollständige Implementierung von ID Austria jedoch aufgrund von Ressourcenknappheit und Scope-Reduktion nicht realisiert werden. Stattdessen wurde in der vorliegenden Version der Anwendung eine E-Mail-Passwort-Authentifizierung mit Salt umgesetzt. Daher besteht ein wesentliches Ziel der Arbeit auch darin, die geplante Integration von ID Austria konzeptionell zu beschreiben und einzuordnen. Es soll aufgezeigt werden, an welchen Stellen die bestehende Architektur dafür angepasst werden müsste und welche sicherheitstechnischen Vorteile sich daraus ergeben würden.

Zusammenfassend verbindet die Arbeit somit theoretische Grundlagen, Anforderungsanalyse, Darstellung der realen Implementierung und Konzeption einer zukünftigen ID-Austria-Integration. Auf diese Weise soll bewertet werden, welchen Nutzen ID Austria für eine sichere digitale Vereinsverwaltung haben kann und welche Schritte für eine vollständige Umsetzung künftig notwendig wären.

1.1.2 Abgrenzung und Umfang

Diese Diplomarbeit untersucht, wie ID Austria als sichere Authentifizierungsmethode für eine mobile Vereinsanwendung genutzt werden kann. Der Schwerpunkt liegt auf den Grundlagen des digitalen Identitätsmanagements, der Analyse der Anforderungen einer Vereins-App sowie der Darstellung der bestehenden Systemarchitektur. Darüber hinaus wird die geplante Einbindung von ID Austria konzeptionell beschrieben.

Eine vollständige praktische Implementierung von ID Austria ist jedoch nicht Bestandteil der Arbeit. Sie wurde aufgrund von Scope-Reduktion und Ressourcenknappheit nicht umgesetzt. Stattdessen verwendet die entwickelte Anwendung derzeit eine E-Mail-Passwort-Authentifizierung mit Salt.

1.1.3 Bedeutung der Arbeit im größeren Kontext

Diese Arbeit ist auch über den konkreten Anwendungsfall hinaus relevant, da sie ein zentrales Thema der Digitalisierung behandelt: die sichere digitale Identifikation von Personen. Immer mehr Anwendungen müssen sensible personenbezogene Daten sichern und gleichzeitig eine einfache Nutzung ermöglichen. Staatliche Identitätslösungen wie ID Austria können dabei eine wichtige Rolle spielen, da sie Sicherheit, Ver-

trauen und Benutzerfreundlichkeit miteinander verbinden.

Am Beispiel einer Vereins-App zeigt die Arbeit, welche Anforderungen und Möglichkeiten mit der Nutzung einer solchen Lösung verbunden sind. Damit leistet sie einen Beitrag zur Frage, wie moderne Authentifizierungsverfahren in digitale Systeme eingebunden werden können und welche Bedeutung sie für die zukünftige Digitalisierung von Organisationen haben.

1.2 Einleitung Christian Langsteiner

Das moderne Internet wird heute auf einer Vielzahl unterschiedlicher Geräte genutzt. Menschen surfen nicht nur am Desktop-Computer, sondern auch auf Laptops, Tablets, Smartphones oder sogar auf Fernsehern. Jedes dieser Geräte besitzt eine andere Bildschirmgröße, Auflösung und Ausrichtung. Damit Webseiten auf allen Endgeräten angenehm lesbar und bedienbar bleiben, braucht es eine Anpassung der Darstellung. Dieser Ansatz wird als Responsive Webdesign (RWD) bezeichnet und beschreibt eine Methode, Webseiten so zu gestalten, dass sie sich dynamisch an verschiedene Bildschirmgrößen anpassen und gleichzeitig eine gute Benutzbarkeit gewährleisten[CL:Web22]. MDN fasst RWD als einen Ansatz zusammen, der Weblayouts flexibel macht und für ein Multi-Device-Web optimiert[CL:Web22].

1.2.1 Überblick und Problemstellung

Früher wurden Websites oft für einen einzigen Bildschirm entworfen. Mit dem Aufkommen mobiler Geräte wurden dann zusätzliche mobile Versionen erstellt. Solche starren Lösungen sind heute nicht mehr zeitgemäß, weil ständig neue Geräteklassen entstehen. Responsive Design löst dieses Problem, indem es Layouts mithilfe flexibler Raster und relativer Einheiten gestaltet und bei Bedarf Media Queries einsetzt[CL:Web22]. Das bedeutet: Die Seite ändert ihr Erscheinungsbild automatisch, wenn der vorhandene Platz zu groß oder zu klein wird. Eine Spalte kann sich auf einem Smartphone über die ganze Breite erstrecken, während derselbe Inhalt auf einem großen Desktop in mehrere Spalten aufgeteilt wird. Auch Schriftgrößen, Bilder und Navigationsmenüs passen sich an. Der W3C-Entwurf zu Media Queries erklärt, dass diese Technik Medienabhängigkeit erweitert, indem man die Breite, Höhe oder Auflösung des Gerätes abfragt und darauf basierend Regeln definiert[CL:Web25].

In der Praxis zeigt sich, dass viele Websites diese Prinzipien noch nicht konsequent umsetzen. Sie nutzen feste Pixelgrößen, weshalb der Text auf kleinen Bildschirmen zu

winzig oder auf großen Bildschirmen zu dominant wirkt. Außerdem laden sie oft Bilder in Desktop-Größe, die auf Mobilgeräten unnötig viel Datenvolumen verbrauchen. Laut einem web.dev-Artikel kann die Übertragung großer Bilder zwei- bis viermal so viel Daten kosten wie nötig[CL:Web27], was bei mobilen Verbindungen spürbare Verzögerungen verursacht und für den Besucher teuer werden kann[CL:Web28]. Nicht zuletzt sind viele Menüs und Schaltflächen nicht für Touch-Bedienung optimiert. Eine nicht responsive Seite führt damit zu schlechter Benutzererfahrung und kann sogar Besucher abschrecken. Diese Problematik bildet den Kern der vorliegenden Diplomarbeit: Es soll untersucht werden, wie man Webseiten so umsetzt, dass sie auf verschiedenen Geräten funktionieren, schnell laden, gut lesbar sind und barrierefreie Inhalte bieten.

1.2.2 Relevanz des Themas

Responsive Design ist heute wichtiger denn je, weil das Web allgegenwärtig ist. Nutzer erwarten, dass sie Informationen und Dienste jederzeit auf ihren Geräten abrufen können. Firmen, Vereine und öffentliche Einrichtungen brauchen daher Webauftritte, die auf Smartphones ebenso gut funktionieren wie auf großen Bildschirmen. Eine fehlerhafte Darstellung oder lange Ladezeiten werden schnell als unprofessionell wahrgenommen. Ein weiterer Faktor ist Barrierefreiheit: Menschen mit Sehbehinderungen oder motorischen Einschränkungen sind darauf angewiesen, dass Websites vergrößerbare Texte, alternativen Bildbeschreibungen und ausreichend große Buttons bieten. Die W3C-Spezifikation zu Media Queries erlaubt, Stile auf bestimmte Geräte und Eigenschaften anzupassen[CL:Web25]. Ebenso betont MDN, dass moderne Layout-Techniken wie Flexbox und Grid responsive Websites vereinfachen[CL:Web22].

Die Relevanz dieses Themas zeigt sich auch in der Leistungsoptimierung. Studien und Artikel warnen davor, zu große Bilddateien auszuliefern. Google verweist darauf, dass unnötig große Bilder den wichtigsten Ladeindikator, den *Largest Contentful Paint* (LCP), verschlechtern[CL:Web27]. Mightybytes weist darauf hin, dass bei mobilen Verbindungen die Datenmenge reduziert werden muss, um Kosten zu sparen und die Umwelt zu schonen[CL:Web28]. Schließlich betrifft Responsive Design nicht nur die Technik, sondern auch die Gestaltung: Navigationsmenüs müssen auf kleinen Bildschirmen platzsparend sein[CL:Web31], Schriftgrößen und Zeilenlängen müssen sich verändern, damit Texte angenehm lesbar bleiben[CL:Web36].

1.2.3 Zielsetzung und Forschungsfragen

Diese Diplomarbeit hat sich zum Ziel gesetzt, die wichtigsten Konzepte und Techniken des Responsive Webdesigns zu untersuchen und anschließend auf ein selbst gewähl-

tes Projekt anzuwenden. Konkret sollen folgende Fragen beantwortet werden:

- **Wie lässt sich ein flexibles Layout umsetzen?** Dazu werden flexible Raster, moderne CSS-Techniken wie Flexbox und Grid und deren Kombination mit Media Queries analysiert[CL:Web22].
- **Wie können Bilder und andere Medien performant eingebunden werden?** Hierzu werden Strategien zur Reduzierung der Datenmenge untersucht, insbesondere der Einsatz von 'srcset' und 'sizes' sowie das Zuschneiden von Bildern, um unterschiedliche Auflösungen zu bedienen[CL:Web27].
- **Welche Navigationsmuster eignen sich für verschiedene Bildschirmgrößen?** Es soll geklärt werden, wann eine Top-Navigation, Footer-Navigation, ein Toggle-Menü oder ein Off-Canvas-Menü sinnvoll ist[CL:Web31].
- **Wie wird Typografie responsiv gestaltet?** Das umfasst die Anpassung von Schriftgröße, Zeilenlänge und Zeilenhöhe sowie die Verwendung relativer Einheiten ('em', 'rem') statt fester Pixel, um die Zugänglichkeit zu verbessern[CL:Web35].
- **Wie lässt sich der Nutzerfreundlichkeit gerecht werden?** Dazu zählen Barrierefreiheit (Alt-Texte, Tastaturbedienung), schnelle Ladezeiten und eine klare Benutzerführung. Insbesondere wird auf barrierefreie Bildbeschreibungen eingegangen [CL:Web29].

1.2.4 Methodik und Aufbau der Arbeit

Die Arbeit ist in zwei große Teile gegliedert: einen theoretischen Teil und einen praktischen Teil. Zuerst werden die Grundlagen des Responsive Webdesigns erarbeitet. Dazu zählen die Definition von RWD, die historischen Anfänge von Media Queries[CL:Web25], aktuelle Layout-Techniken wie Flexbox und Grid[CL:Web22], responsive Bilder[CL:Web27], Navigationsmuster[CL:Web31] und responsiver Umgang mit Typografie[CL:Web35]. Die Literaturrecherche stützt sich ausschließlich auf die zuvor genannten Quellen.

Im praktischen Teil wird das Gelernte auf ein eigenes Projekt angewendet. Dazu wird eine Beispielwebsite konzipiert, die sich an eine festgelegte Zielgruppe richtet. Es wird ein geeigneter Technologie-Stack gewählt (HTML, CSS, JavaScript sowie Flutter für mobile Anwendungen), und anschließend wird schrittweise ein responsives Layout implementiert. Während der Umsetzung werden Screenshots, Codebeispiele und Testprotokolle dokumentiert. Abschließend erfolgt eine Reflexion: Welche Methoden haben gut funktioniert, wo gab es Probleme und wie könnte das Ergebnis weiter verbessert werden? Der Vergleich zwischen Theorie und Praxis bildet die Grundlage für das Kapitel zum Projektbezug.

1.2.5 Abgrenzung und Zielgruppe

Diese Arbeit konzentriert sich auf die Gestaltung und Umsetzung des Frontend-Bereichs einer Website. Serverseitige Themen wie Datenbanken oder Server-seitige Programmiersprachen werden nicht behandelt. Auch Frameworks wie React oder Angular werden nur am Rande erwähnt; der Fokus liegt auf klassischen Webstandards (HTML, CSS, JavaScript) und dem Einsatz von Flutter für mobile Anwendungen. Untersucht werden typische Endgeräte wie Smartphones, Tablets und Desktop-Computer. Extrem große Displays (etwa Smart-TVs) oder exotische Geräte bleiben außer Acht. Außerdem werden barrierefreie Aspekte wie Alt-Texte, Tastaturbedienung und Zoomfähigkeiten berücksichtigt, jedoch keine speziellen Hilfsmittel für Menschen mit schweren Behinderungen. Die Zielgruppe der Arbeit sind vor allem Webentwicklerinnen und -entwickler auf HTL-Niveau sowie Lehrpersonen, die einen praxisnahen Lehrgang zum Thema Responsive Webdesign suchen.

1.2.6 Aufbau der Arbeit

Kapitel 1 (diese Einleitung) führt in das Thema ein, stellt die Problemstellung vor, begründet die Relevanz und definiert die Ziele. Kapitel 2 beschäftigt sich mit den theoretischen Grundlagen des Responsive Webdesigns. Es werden der Hintergrund, flexible Raster, Media Queries und moderne Layout-Techniken vorgestellt. Kapitel 3 widmet sich der Usability im Webdesign. Hier werden grundlegende Regeln für Benutzerfreundlichkeit, barrierefreie Gestaltung und Informationsarchitektur behandelt. Kapitel 4 beschreibt die Umsetzung einer responsiven Website im Detail. Dort werden die zuvor erarbeiteten Konzepte praktisch angewendet, ergänzt durch Codebeispiele in CSS und Flutter. Kapitel 5 (Projektbezug) stellt das eigentliche Diplomprojekt vor und erklärt, wie die Theorien auf dieses Projekt übertragen wurden. Schließlich fasst Kapitel 6 die Ergebnisse zusammen, beantwortet die Ausgangsfragen, zieht ein Fazit und gibt einen Ausblick auf mögliche Weiterentwicklungen.

1.3 Einleitung David Steininger

Barrierefreiheit, insbesondere im digitalen Raum, gewinnt in den letzten Jahren immer mehr an Bedeutung. Sowohl rechtliche Grundlagen als auch technische Standards entwickeln sich laufend weiter. In dieser Diplomarbeit geht es darum, was genau die aktuellen Gesetze und Regelungen in der EU und Österreich sind, welche technischen Standards aktuell sind und die Gesetze erfüllen. Es wird außerdem Bezug auf ein reales Projekt, eine Polizeisportvereins-App, und die in ihr umgesetzten Lösungen gehen.

1.3.1 Problemstellung und Relevanz der Thematik

Digitale Anwendungen, Websites und mobile Apps sind heute wichtige Schnittstellen zwischen Staat, Wirtschaft und Gesellschaft. Gleichzeitig besteht jedoch die Gefahr, dass bestimmte Bevölkerungsgruppen von diesen digitalen Angeboten ausgeschlossen werden, wenn sie nicht barrierefrei gestaltet sind. Besonders betroffen sind Menschen mit Behinderungen und ältere Personen.

Digitale Barrierefreiheit beschreibt die Eigenschaft digitaler Systeme, von möglichst vielen Personen unabhängig von individuellen Einschränkungen verwendet und verstanden werden zu können. In der Praxis zeigt sich jedoch, dass viele digitale Produkte und Dienstleistungen weiterhin erhebliche Zugänglichkeitsmängel aufweisen. Fehlende Alternativtexte, unzureichende Tastaturbedienbarkeit, komplexe Navigation oder nicht barrierefreie Dokumente stellen nach wie vor häufig Hürden dar. Diese Probleme sind nicht nur technisch, sondern haben auch rechtliche und gesellschaftliche Hintergründe. [SD:Web08] [SD:Web09]

1.3.2 Zielsetzung und Forschungsfragen

Ziel dieser Arbeit ist es, digitale Barrierefreiheit im Kontext rechtlicher Rahmenbedingungen in Europa und Österreich zu analysieren und deren Bedeutung für die technische Umsetzung von Software- und Webprojekten auszuarbeiten. Dabei sollen sowohl die theoretischen Grundlagen als auch konkrete gesetzliche Vorgaben und technische Standards betrachtet werden.

Daraus ergeben sich folgende Forschungsfragen:

Welche rechtlichen Anforderungen bestehen auf EU- und nationaler Ebene zur digitalen Barrierefreiheit?

Welche technischen Standards sind für die Umsetzung relevant und wie werden sie umgesetzt?

Welche Herausforderungen treten bei der praktischen Umsetzung barrierefreier digitaler Systeme auf?

1.3.3 Aufbau der Arbeit

Die Diplomarbeit ist in sieben Kapitel unterteilt. Nach der Einleitung werden in Kapitel 2 die theoretischen Grundlagen zur Inklusion im digitalen Raum behandelt. Dazu gehören grundlegende Begriffsdefinitionen, Dimensionen digitaler Barrierefreiheit sowie die Betrachtung unterschiedlicher Nutzergruppen mit besonderen Bedürfnissen.

In Kapitel 3 geht es um die rechtlichen Rahmenbedingungen in Europa und Österreich. Es werden relevante europäische Richtlinien, österreichische Gesetze sowie internationale Standards aufgearbeitet. Der Abschluss dieses Kapitels ist eine Analyse der Chancen, Herausforderungen und offenen Fragen bei der praktischen Umsetzung.

In Kapitel 4 werden typische Probleme in der Praxis sowie mögliche Lösungsansätze präsentiert. Dabei wird auf technische, organisatorische und gesellschaftliche Ebene eingegangen. Weiterhin geht es um Accessibility by Design und ein paar Best Practices und innovative Ansätze.

Kapitel 5 geht näher auf die technischen Anforderungen und Standards ein und stellt konkrete Hilfsmittel für Menschen mit Behinderung vor und zeigt Codebeispiele zur Umsetzung digitaler Barrierefreiheit vor.

In Kapitel 6 wird ein konkretes Beispiel anhand einer Polizei-Sportvereins-App demonstriert.

Abschließend fasst Kapitel 7 die wichtigsten Ergebnisse zusammen und gibt einen Ausblick auf zukünftige Entwicklungen im Bereich digitaler Inklusion.

1.3.4 Methodisches Vorgehen

Zunächst werden gesetzliche Regelungen auf europäischer und nationaler Ebene ausgewertet, sowie relevante EU-Richtlinien. Ergänzend werden internationale technische Standards wie die WCAG 2.1 und die EN 301 549 herangezogen. Weiterhin wird auf typische Herausforderungen eingegangen und Lösungsansätze der praktischen Durchführung eingegangen. Schlussendlich werden einige praktische Umsetzungen anhand einer eigenen App demonstriert.

Dies ermöglicht einen umfassenden Blick auf das Thema "Barrierefreiheit im Digitalen Raum".

1.4 Einleitung Nadine Pöll

Unternehmen aus dem Bereich der Informatik sehen sich heutzutage der Herausforderung gegenüber, den festgelegten Standards und Erwartungen an eine Software gerecht zu werden. Dazu gehört unter anderem, Fehler rechtzeitig zu identifizieren und ihnen vorzubeugen. Insbesondere die Softwareentwicklung nimmt dabei eine zentrale Rolle ein. In dieser Diplomarbeit wird der Frage nachgegangen, wie bedeutend die Qualitätssicherung in der Softwareentwicklung ist und auf welche Weise sie umgesetzt werden kann. Das Hauptaugenmerk liegt auf der Definition von Qualität, ihrer Rolle im Entwicklungszyklus, den Möglichkeiten zur Qualitätsprüfung und ihren besonderen Anforderungen an sicherheitsrelevante Apps und Webseiten. Es wird unter anderem auch der Bezug zu meinem Projekt für eine Polizeisportvereins-App behandelt. [PN:Web08]

1.4.1 Ziele und Aufbau

Das Ziel dieser Arbeit wird es sein, die theoretischen Grundlagen zu behandeln und verschiedene praktische Umsetzungsmöglichkeiten sowie deren Überprüfbarkeit zu diskutieren. Die Arbeit gliedert sich in sechs Kapitel. Nach der Einführung (Kapitel 1.4) werden im ?? Kapitel die theoretischen Grundlagen der Qualitätssicherung dargestellt. Im ?? Kapitel werden die Testmethoden zur Qualitätssicherung behandelt, und es werden unterschiedliche Ansätze vorgestellt, um die Qualitätsstandards von Software zu sichern.

Die Qualitätssicherung der Polizeisportverein-App wird im letzten Abschnitt (Kapitel ??) behandelt, an dem unsere Projektgruppe nebenbei arbeitet. In diesem Kapitel stehen vor allem die praktischen Aspekte der Qualitätssicherung im Vordergrund.

1.4.2 Qualitätssicherung in Softwareprojekten

In Softwareprojekten ist die Qualitätssicherung ein kompromissloser Prozess: Sie sorgt dafür, dass das Softwareprodukt sowie die Prozesse der Entwicklung und Wartung den festgelegten Anforderungen entsprechen. In der Literatur wird diese Zusammenfassung der Maßnahmen und Hilfsmittel als "Qualitätssicherung" bezeichnet. Es beinhaltet sowohl administrative als auch analytische Aufgaben und ist für das Management entscheidend, um die Qualitätspolitik festzulegen und deren Einhaltung zu überwachen. Eine effiziente Qualitätssicherung ist ein Schlüssel zur Verbesserung der Sicherheit der Software. Durch strukturierte Tests lassen sich Schwachstellen und Risiken aufdecken und beseitigen, was das Vertrauen der Kunden stärkt.[PN:Web08]

Die Qualitätssicherung hat drei Hauptaufgaben: die Planung der Qualität, die Steuerung der Qualität und die Prüfung der Qualität. Der Qualitätssicherungsprozess zeigt durch die frühzeitige Erkennung von Fehlern, dass er kosteneffizient und ressourcenschonend ist. Das führt zu einer Senkung der Anpassungskosten.[PN:Web08]

Ein weiterer Pluspunkt der Qualitätssicherung ist die Optimierung der Benutzererfahrung. Indem hohe Qualitätsstandards eingehalten werden, ist sichergestellt, dass die Software leicht zu bedienen ist und den Erwartungen der Endnutzer entspricht. Außerdem ermöglicht ein optimierter Qualitätssicherungsprozess eine Beschleunigung der Entwicklung. Durch das frühzeitige Erkennen und Lösen von Problemen können die Entwicklungszyklen verkürzt und neue Funktionen hinzugefügt werden, ohne dass dies negative Auswirkungen auf das System hat.[PN:Web09][PN:Web10]

Es ist entscheidend, dass wir die Qualitätskontrolle nicht nur dazu nutzen, um Fehler zu vermeiden, sie hilft auch, die Kosten im Rahmen zu halten und sicherzustellen, dass die Software allen notwendigen Vorschriften entspricht. Fehler, die erst spät im Entwicklungsprozess entdeckt werden, können hohe Kosten und viel Zeit verursachen, sie gefährden somit das Risiko, dass das Projekt verzögert wird und die Kundenzufriedenheit leidet. In einem Wettbewerb, in dem Kunden immer höhere Erwartungen an die Softwarequalitäten stellen, ist die Qualitätssicherung eine fundamental wichtige Strategie.[PN:Web08][PN:Web10]

Die Qualitätssicherung spielt eine entscheidende Rolle dabei, das Vertrauen zwischen Unternehmen und Kunden zu stärken, weil sie gewährleistet, dass das Endprodukt eine sehr gute Qualität aufweist. Die Qualitätssicherung hat durch ihre feste Verankerung in den Geschäftsprozessen und durch das Ermöglichen von fortlaufenden Verbesserungen und Effizienzsteigerungen eine unbestreitbare Bedeutung im Softwareentwicklungsprozess.[PN:Web08]

1.4.3 Herausforderungen der Softwarequalität

Die Gewährleistung der Softwarequalität ist in aktuellen Entwicklungsprojekten eine zentrale Herausforderung. Der Wettbewerbsdruck führt dazu, dass die *Time-to-Market* – die Zeit von der Produktidee bis zur Markteinführung – erheblich verkürzt wird. Dies führt dazu, dass Unternehmen die Herausforderung meistern müssen, in immer kürzeren Zeiträumen qualitativ hochwertige Software zu liefern. Die Fokussierung auf Schnelligkeit kann dazu führen, dass man entscheidende Maßnahmen zur Qualitätssicherung übersieht. Es ist schwierig, eine angemessene Balance zwischen der Zeit für die Entwicklung, den Ausgaben und der Qualität zu erreichen, ohne die langfristige Wartbarkeit und Zuverlässigkeit der Software zu beeinträchtigen.[PN:Web10][PN:Web09]

Ein zusätzlicher Gesichtspunkt betrifft die steigende Komplexität moderner Softwaresysteme. Heutige Anwendungen bestehen oft aus vielen Komponenten, Microservices und externen Schnittstellen, die alle miteinander verknüpft sind. Je mehr Systeme vorhanden sind, desto größer ist das Risiko von Störungen, dies erschwert die Fehlerverfolgung erheblich. Das Qualitätsmanagement sollte das gesamte System im Blick haben, um frühzeitig Wechselwirkungen und Abhängigkeiten zu erkennen, anstatt sich nur auf einzelne Module zu konzentrieren.[PN:Web09]

Außerdem werden Sicherheitsanforderungen immer wichtiger. Wegen Cyberangriffen, Datenschutzbestimmungen und regulatorischen Vorgaben ist es für Unternehmen unerlässlich, Sicherheitsaspekte als festen Bestandteil der Softwarequalität zu integrieren. Wenn Zugriffskontrollen fehlen oder Sicherheitslücken bestehen, können nicht nur finanzielle Verluste entstehen, sondern auch das Vertrauen der Kunden stark geschädigt werden.[PN:Web11]

Schließlich ist die fortlaufende Verbesserung von Technologien – wie etwa durch die Einführung von Cloud-Architekturen, künstlicher Intelligenz oder DevOps-Praktiken – ebenfalls eine Herausforderung. Um trotz der hohen Innovationsgeschwindigkeit eine konstant hohe Softwarequalität zu sichern, sind flexible, automatisierte und skalierbare Qualitätssicherungsprozesse notwendig.[PN:Web11]

Kapitel 2

Identitätsmanagement im digitalen Raum

Die Identität im digitalen Raum ist ausschlaggebend, um Zugriffe und Rollen innerhalb eines Unternehmens und im digitalen Raum zuordnen zu können.

2.1 Was ist digitale Identität?

“Eine digitale Identität ist ein Profil oder ein Satz von Informationen, die mit einem bestimmten Benutzer, einer Maschine oder einer anderen Entität in einem IT-Ökosystem verbunden sind. Digitale IDs helfen Computersystemen, zwischen verschiedenen Benutzern zu unterscheiden, um den Zugriff zu kontrollieren, Aktivitäten zu verfolgen, Betrugserkennung und Cyberangriffe zu verhindern.”[ARB:Web01]

2.1.1 Die vier Kernprozesse des IAM

Identity Access Management (kurz IAM) verfolgt das Ziel, alle Zugriffe fachgerecht zu verarbeiten und keine nicht autorisierten Zugriffe zuzulassen. IAM stützt sich dabei auf vier zentrale Säulen:

1. **Verwaltung:** Identitätsverwaltung bezeichnet die Erzeugung, Verwaltung und die sichere Entsorgung von Entitätsidentitäten in einem System. Sie wird in einer

Datenbank oder einem Verzeichnis gespeichert, welches als *Single Source of Truth* (SSOT) agiert.

2. **Authentifizierung:** Im Zuge der Anmeldung von Benutzern in einem System oder dem Zugriff auf die Ressourcen desselben ist eine Bestätigung der Identität unter Zuhilfenahme von Authentifizierungsfaktoren erforderlich. Im vorliegenden Kontext wird bei menschlichen Nutzern entweder ein Passwort oder ein biometrischer Scan verwendet. Bei nicht-menschlichen Benutzern wird ein digitales Zertifikat geteilt.
3. **Autorisierung:** Nach der Verifizierung eines Benutzers werden die Zugriffsrechte auf das System oder die Ressource geprüft. Autorisierung erfolgt stets nach der Authentifizierung. Diese zwei Komponenten agieren eng miteinander und bilden zusammen die „Zugriffsmanagementkomponente des Identitäts- und Zugriffsmanagements.“
4. **Prüfung (Auditing):** Die Prüfung bezeichnet die Sicherstellung der Funktionalität aller IAM-Komponenten. Darunter fällt die Protokollierung der Benutzerzugriffe, um sicherzustellen, dass niemand auf Daten zugreift, für die er keine Berechtigung hat, und dass niemand mit Berechtigungen diese missbraucht.

[ARB:Web02]

2.1.2 Single Sign-On (SSO)

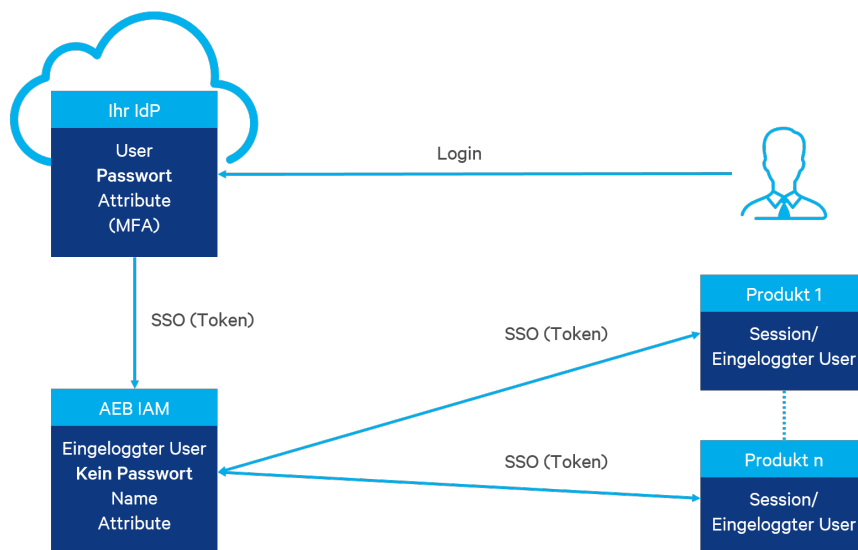


Abbildung 2.1: Funktionsweise von Single Sign-On (Quelle: [ARB:Web05])

Das Single Sign-On ist ein Authentifizierungsverfahren, welches Benutzern ermöglicht, sich mit einer einzigen Authentifizierung bei mehreren Diensten zu registrieren. Durch die Verwendung von SSO müssen sich Benutzer nur ein einziges Passwort merken – kritische Sicherheitsrisiken wie die repetitive Nutzung desselben Passworts werden deutlich reduziert. Durch die Optimierung der Benutzervalidierung und den Wegfall des wiederholten eingebens von Benutzername und Passwort wird der Zugriff auf geschützte Ressourcen deutlich erleichtert [ARB:Web03].

2.2 OAuth 2.0 – Autorisierung

Wenn Webapplikationen auf Ressourcen eines Nutzers zugreifen wollen, nutzen sie Open Authorization (OAuth), um auf andere Applikationen zuzugreifen, die die Daten für den Nutzer hosten. OAuth 2.0 ermöglicht dies mithilfe von Zugriffstokens, die eingeschränkten Zugriff gewähren, ohne die Bekanntgabe von Passwörtern oder sonstigen Anmeldedaten. Meist wird hierfür das JSON Web Token Format genutzt, da der Aussteller dieses Tokens im Token selbst Informationen und Daten mitgeben kann [ARB:Web04].

2.2.1 Die 4 Rollen

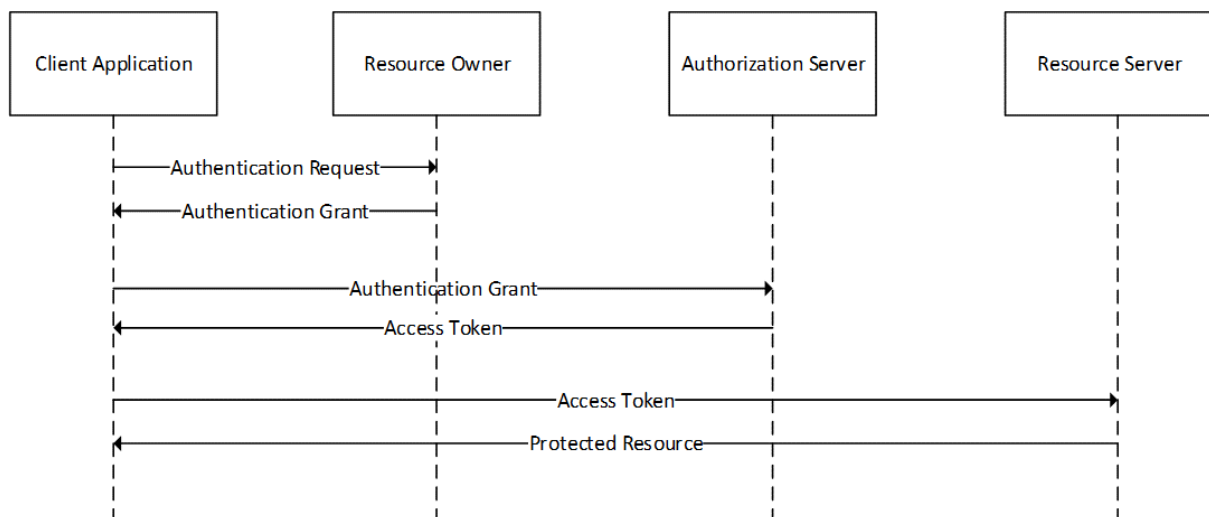


Abbildung 2.2: Rollenverteilung im OAuth 2.0 Standard (Quelle: [ARB:Web05])

Der OAuth 2.0 Standard unterscheidet zwischen vier Rollen mit jeweils verschiedenen Aufgaben [ARB:Web05]:

- **Client:** Der Client ist das System, das den Zugriff auf die geschützten Ressourcen anfordert. Damit der Client auf Ressourcen zugreifen kann, muss er über den notwendigen Zugriffstoken verfügen.
- **Resource Owner:** Der Resource Owner überprüft, ob der Client die Rechte hat, um auf die geschützte Ressource zuzugreifen. Er verweigert oder erlaubt den Zugriffsversuch des Clients.
- **Authorization Server:** Da der Client keinen Zugriff auf die Anmeldedaten des Benutzers hat, muss er sich beim Authorization Server authentifizieren. Nach erfolgreicher Authentifizierung übergibt der Server dem Client einen Access Token, mit dem er auf die Ressource Zugriff erhält.
- **Resource Server:** Die Verwaltung und Speicherung der Benutzerressourcen ist die Aufgabe des Resource Servers. Nachdem der Server den Access Token validiert hat, gewährt er den Zugriff auf die jeweilige Ressource, die der Client angefragt hat.

2.2.2 Was ist der Authorization Code Flow?

Der Authorization Code Flow stellt einen OAuth-Flow mit zweistufiger Autorisierung dar, in dessen Verlauf der Client einen kurzlebigen Autorisierungscode (der über eine Server-Weiterleitung bereitgestellt wird) gegen ein Zugangs-Token eintauscht. Diesen Code tauscht der Client dann server-seitig gegen das eigentliche Access Token ein. Der Vorteil dabei ist, dass das Access Token nie im Browser sichtbar wird und so nicht durch Angriffe wie Cross-Site-Scripting abgefangen werden kann. Wegen seiner hohen Sicherheit gilt er heute als Standard für mobile und Web-Apps [ARB:Web06].

2.2.3 Wie funktioniert der Authorization Code Flow?

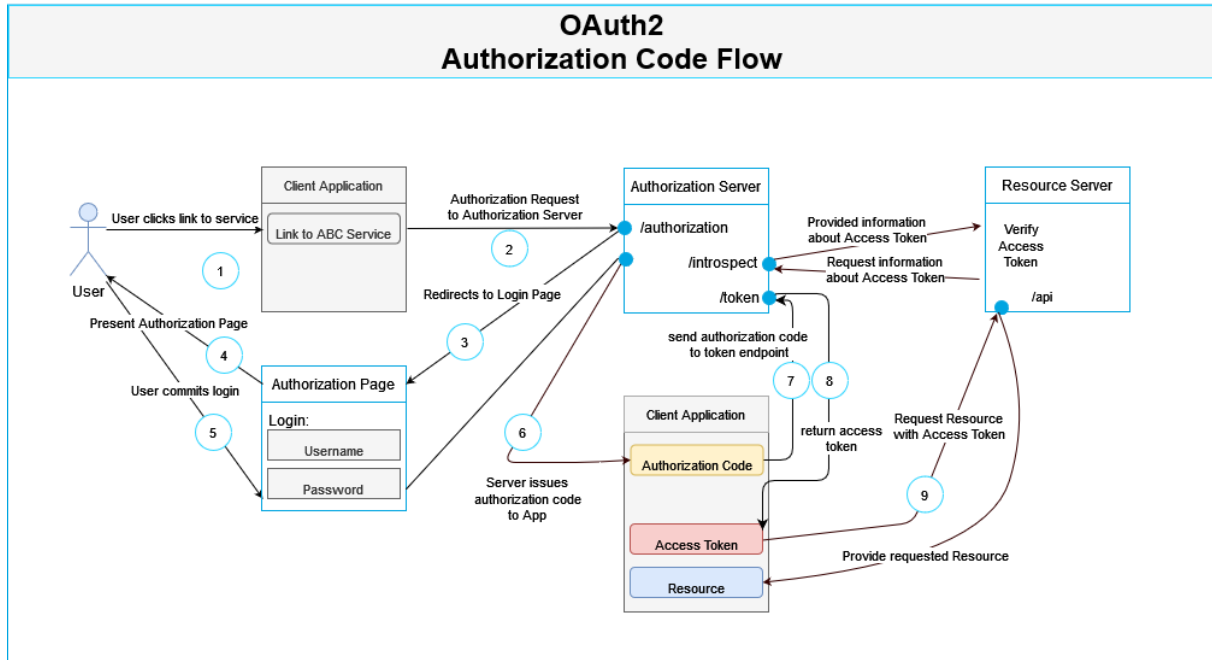


Abbildung 2.3: OAuth2 Authorization Code Flow (Quelle: [ARB:Web06])

1. Der User möchte über einen Link auf eine extern in seinem Namen gehostete Ressource des Host Servers zugreifen.
2. Der Client sendet an die `/authorization`-Schnittstelle des Authorization Servers eine Autorisierungsanfrage:

```

1 GET {Authorization Endpoint}
2 ?response_type=code
3 &client_id={Client ID}
4 &redirect_uri={Redirect URI}
5 &scope={Scopes}
6 &state={Arbitrary String}
7 &code_challenge={Challenge}
8 &code_challenge_method={Method}
9 HTTP/1.1
10 HOST: {Authorization Server}

```

Listing 2.1: Beispiel Authorization Request (Quelle: [ARB:Web06])

3. Der Authorization Server antwortet mit einer Authorization Page.
4. Die Authorization Page wird dem User präsentiert.

5. Der User gibt seine Anmeldedaten auf der Login-Seite des Authorization Servers ein und bestätigt die Autorisierungsanfrage.
6. War die Authentifizierung erfolgreich, teilt der Authorization Server dem Client einen Authorization Code mit. Beispiel-Response:

```
1 HTTP/1.1 302 Found
2 Location: {Redirect URI}
3 ?code={Authorization Code}
4 &state={Arbitrary String}
```

Listing 2.2: Beispiel Authorization Response (Quelle: [ARB:Web06])

7. Der Client schickt seinen Authorization Code an die /token-Schnittstelle des Authorization Servers:

```
1 POST {Token Endpoint} HTTP/1.1
2 Host: {Authorization Server}
3 Content-Type: application/x-www-form-urlencoded
4 grant_type=authorization_code
5 &code={Authorization Code}
6 &redirect_uri={Redirect URI}
7 &code_verifier={Verifier}
```

Listing 2.3: Beispiel Token Request (Quelle: [ARB:Web06])

8. Der Server prüft den Authorization Code. Bei korrektem Code liefert er dem Client das Access Token server-seitig aus:

```
1 HTTP/1.1 200 OK
2 Content-Type: application/json; charset=UTF-8
3 Cache-Control: no-store
4 Pragma: no-cache
5 {
6   "access_token": "{Access Token}",
7   "token_type": "{Token Type}",
8   "expires_in": {Lifetime In Seconds},
9   "refresh_token": "{Refresh Token}",
10  "scope": "{Scopes}"
11 }
```

Listing 2.4: Beispiel Token Response (Quelle: , [ARB:Web06])

9. Da der Tokenaustausch direkt zwischen Client und Authorization Server stattfindet, bekommt der Browser das Access Token nie zu sehen. Der Client kann nun mit dem Access Token auf die geschützte Ressource des Resource Servers zugreifen [ARB:Web06].

2.3 OpenID Connect – Authentifizierung

OpenID Connect ist ein tokenbasierter Authentifizierungsstandard, der auf OAuth 2.0 aufbaut und einen zentralen Identity Provider zur Benutzerauthentifizierung verwendet. Der Standard setzt eine einmalige Anmeldung beim IdP voraus und ermöglicht danach die Übertragung der Benutzeridentität per Token an weitere Systeme. Die Kommunikation geschieht dabei primär zwischen dem Identity Provider und dem Client, der in diesem Kontext als *Relying Party* bezeichnet wird [ARB:Web07].

2.3.1 Identity Token

Der von OIDC eingeführte ID Token dient zur Identifizierung von Benutzern. Er arbeitet im JSON Web Token Format und besteht aus drei zentralen Feldern:

- **Subject:** Fungiert als eindeutige Kennung des Benutzers.
- **Audience:** Gibt an, für wen der Token generiert wurde.
- **Issuer:** Enthält die ausstellende Instanz des JWT.

Das Ziel des ID Tokens ist es, Informationen über den Benutzer vom Issuer zum Client zu übertragen. ID Tokens sollten jedoch niemals für Autorisierung genutzt werden oder Informationen zu einer Autorisierung beinhalten – sie dienen ausschließlich zur Identifizierung [ARB:Web07].

2.3.2 JWT – JSON Web Token

„Ein JSON Web Token ist ein nach RFC 7519 genormtes Access Token und ermöglicht es, Daten sicher zwischen zwei Parteien auszutauschen. Es enthält dabei alle wichtigen Informationen über eine Entität, wodurch keine Datenbankabfrage erforderlich ist und die Sitzung nicht auf dem Server gespeichert werden muss (Stateless Session).“ [ARB:Web10]

Da dieser Access Token signiert werden kann und dabei sichere Auskunft über Absender und dessen benötigte Zugriffsrechte bieten kann, ist der JWT bei Authentifizierungsvorgängen besonders beliebt. Da die Hauptkommunikation zwischen Server- und Clientanwendung verläuft, bekommt der Nutzer selbst nur indirekt – durch beispielsweise die Eingabe von Benutzername und Passwort in einer Maske – Kontakt mit dem Token [ARB:Web10].

2.3.3 Refresh Token

Ein Refresh Token dient dazu, einen neuen, gültigen Access Token anzufordern, und ist daher länger gültig als der Access Token selbst. Ein potenzielles Problem entsteht, wenn der Refresh Token zu lange gültig bleibt – er könnte dann als Masterkey verwendet werden, um kontinuierlich neue Access Tokens zu generieren. Aus diesem Grund sollte der Refresh Token stets sicher aufbewahrt und seine Gültigkeitsdauer so kurz wie möglich gehalten werden [ARB:Web07].

2.3.4 PKCE

Die Sicherheitserweiterung PKCE (Proof Key for Code Exchange) stellt eine wesentliche Verbesserung der Sicherheit des OAuth 2.0 Authorization Code Flow dar, indem sie eine signifikante Schwachstelle im Sicherheitsmodell behebt. Eine Analyse ergab, dass der Authorization Server ohne den PKCE-Mechanismus nicht in der Lage war, die Identität der Anwendung, welche den Authorization Code einlöst, mit der Anwendung zu verknüpfen, welche den Authentifizierungsprozess initialisierte. Infolge dessen bestand für einen potenziellen Angreifer die Möglichkeit, den Code zu kompromittieren und ihn eigenständig gegen ein Access Token einzutauschen. Die vorliegende Lücke wird durch PKCE geschlossen, indem der Client beim Start des Flows einen willkürlichen Code verifiziert und dessen Hash als code-challenge übermittelt. Beim Token-Tausch muss der originale code-verifier vorgewiesen werden – ohne ihn ist der abgefangene Code wertlos [ARB:Web11].

Kapitel 3

ID Austria

Der kostenlose elektronische österreichische Identitätsnachweis „*ID Austria*“, der die digitale Handysignatur ablöst und bei allen Registrierungsbehörden verfügbar ist, dient zur eindeutigen digitalen Identifizierung. ID Austria ermöglicht die Interaktion mit vielen digitalen Services. Zusätzlich zum Benutzernamen und zum Signaturpasswort ist mindestens eine zweite Authentifizierungsmethode notwendig, um die ID Austria zu nutzen - dies kann mittels Gerätepasswort oder Biometrie geschehen.

Gemäß den geltenden Bestimmungen ist die Ausstellung einer ID Austria an Personen vorbehalten, die das 14. Lebensjahr vollendet haben. Ein weiterer Aspekt, der zu berücksichtigen ist, ist das Vorhandensein eines Smartphones, das den technischen Voraussetzungen entspricht. Zudem ist eine Registrierung bei einer Behörde zur Identitätsfeststellung notwendig. Eine Ausnahme besteht jedoch für bestehende Nutzer der Handy-Signatur, deren identitäre Daten bereits digital erfasst wurden.

ID Austria ist für österreichische Staatsangehörige 5 Jahre nach der Registrierung gültig und kann anschließend entweder um weitere 5 Jahre verlängert oder durch eine Registrierungsbehörde neu ausgestellt werden. Bei nicht-österreichischen Staatsangehörigen ohne Hauptwohnsitz in Österreich ist die ID Austria 3 Jahre lang gültig und ist ohne erneute Registrierung nicht verlängerbar.

Nach dem Erhalt einer ID Austria kann man deren Funktionalitäten nutzen – etwa den E-Ausweis, Login-Funktionalitäten bei privatwirtschaftlichen Anbietern mittels SSO oder elektronische Signaturen. Für die Vereins-App ist dabei besonders die Login-Funktionalität relevant, da sie eine sichere, passwortlose Authentifizierung der Vereinsmitglieder ermöglicht [ARB:Web08].

3.1 Authentifizierungsfaktoren

Zur Sicherstellung der Sicherheit der ID Austria ist eine Zwei-Faktor-Authentifizierung erforderlich. Da die Vollfunktion der ID Austria höheren EU-weiten Sicherheitsstandards unterliegt, ist eine Authentifizierung mittels SMS-TAN nicht möglich. Die zur Verfügung stehenden Alternativen sind[ARB:Web12]:

- **ID Austria / A-Trust Signatur App:** Mittels Benachrichtigung und Signaturaufforderung per Fingerabdruck, Gesichtsscan oder Gerätepasswort kann eine offene Signatur bestätigt werden.
- **FIDO-Sicherheitsschlüssel:** Ein Gerät, das ähnlich wie ein USB-Stick mit einem Computer verbunden werden kann.
- **Signaturkarte:** Eine Karte, die das digitale Signieren von Dokumenten ermöglicht.

Bei den App-basierten Methoden (ID Austria und A-Trust Signatur) erhält der Benutzer nach einem Anmeldeversuch auf seinem Smartphone eine Benachrichtigung zur Durchführung der Signatur. Nach Bestätigung durch Biometrie oder Gerätepasswort und Interaktion mit dem „*Unterschreiben*“ Knopf ist der Benutzer eingeloggt. Falls Benachrichtigungen deaktiviert sind, können offene Signaturen in der App manuell über „*Offene Signaturen abfragen*“ eingesehen werden.

Ein FIDO-Sicherheitsschlüssel stellt eine Alternative zu Smartphone-Apps dar. Nach erfolgreicher Verbindung mit einem Computer generiert er ein Schlüsselpaar, wobei der private Schlüssel auf dem Token verbleibt und der öffentliche Schlüssel mit der ID Austria verknüpft wird. Für die Authentifizierung des Nutzers ist eine Anfrage mittels des privaten Schlüssels erforderlich, die anschließend bestätigt werden muss.

Der Schlüssel kann bei vorhandener ID Austria App einfach hinzugefügt werden, oder auch ohne ID Austria App mittels SMS-TAN oder Post-TAN registriert werden. Bei der Verknüpfung wird man aufgefordert, die Anmeldung mittels PIN auf dem Sicherheitsschlüssel zu bestätigen [ARB:Web12].

3.2 eIDAS Authentifizierungslevel

Die *electronic Identification, Authentication and Trust Services* – kurz **eIDAS** – ist eine EU-Verordnung, die das Ziel verfolgt, EU-weite Standards für digitale Authentifi-

zierung und digitale Services zu setzen. Diese Verordnung unterteilt sich in drei verschiedene Sicherheitslevel, da nicht jeder Online-Dienst dieselbe Sicherheit benötigt [ARB:Web13].

3.2.1 Authentifizierungslevel

- **Level Low:** Bei diesem Level wird keine Identität geprüft. Darunter fallen alle digitalen Services, bei denen eine normale Registrierung genügt und keine großen Folgen bei Missbrauch entstehen würden – wie beispielsweise Nachrichtenportale.
- **Level Substantial:** Dieses Level richtet sich auf Vorgänge, bei denen Missbrauch spürbare Folgen mit sich bringen könnte. Es deckt sensible Daten oder Services mit wichtigen Funktionen ab und erfordert eine robuste Identitätsprüfung sowie starke Authentifizierungsmechanismen.
- **Level High:** Unter dieses Level fallen Dienste mit höchstem Vertrauensniveau und besonderem Risikopotenzial. Hier müssen strenge Identifizierungs- und Authentifizierungsmaßnahmen stattfinden, die darauf ausgelegt sind, Nutzer so umfassend wie möglich vor Angriffen zu schützen. Die digitale Identität soll dabei nahezu zweifelsfrei feststehen.

Bei allen drei Levels geht es darum festzustellen, mit welcher Sicherheit der Zugriff eines Nutzers auf seine Identität zurückzuführen ist [ARB:Web13].

3.2.2 Signaturstufen

Die eIDAS-Verordnung unterscheidet zusätzlich drei Signaturstufen:

- **Einfache elektronische Signatur (EES):** Deckt eine breite Kategorie von elektronischen Signaturen ab, die ohne besondere Identifizierungsanforderungen erstellt werden können.
- **Fortgeschrittene elektronische Signatur (AES):** Setzt eine sichere Bindung zwischen Identität und Signatur voraus, um Manipulation zu verhindern. Sie muss einer unterzeichnenden Person eindeutig zugewiesen sein.
- **Qualifizierte elektronische Signatur (QES):** Die höchste Sicherheitsstufe, die rechtlich auf derselben Ebene wie eine handschriftliche Unterschrift behandelt

wird. Sie setzt ein qualifiziertes Zertifikat und eine qualifizierte Signaturstelle voraus.

Die elektronische Signatur ist nur so vertrauenswürdig wie die Identität, die sie auslöst – je höher die Signaturstufe, desto höher das geforderte Vertrauensniveau. Die Vollfunktion der ID Austria erreicht dabei das höchste Sicherheitslevel sowie die Signaturstufe QES [ARB:Web13].

3.3 SAML2 vs. OIDC

SAML2 und OIDC sind Authentifizierungsprotokolle, welche die Anbindung zwischen dem Service Provider und ID Austria unterstützen. OpenID Connect ist dabei speziell für mobile App Anwendungen, aber auch für Browser Anwendungen interessant, da die Integration mithilfe vieler Libraries einfach ist und eine moderne und webfreundliche Architektur unterstützt wird und nebenbei auch APIs unterstützt werden. SAML2 hingegen ist ein ausgereifter und verbreiteter Standard, der vor allem bei Behörden und im Hochschulumfeld etabliert ist – unterstützt jedoch ausschließlich webbrowsersbasierte Applikationen. Die Kommunikation erfolgt dabei über HTTP-Redirect und POST, mit dem Fokus auf Systeme mit hohen Sicherheitsanforderungen und strengen regulatorischen Vorgaben. Für die Vereins-App war OIDC vorgesehen, da es sich um eine mobile App handelt, die von der modernen Architektur und der breiten Library-Unterstützung profitiert [ARB:Web14].

3.4 Registrierung als Service Provider

Damit Service Owner die ID Austria Authentifizierung für ihre Benutzer anbieten können, müssen sie sich selbst und ihre Applikation zunächst beim ID Austria System registrieren. Der Begriff *Service Owner* bezeichnet Organisationen oder Unternehmen, welche die ID Austria Authentifizierungsmethode nutzen und Service Provider einsetzen möchten. Nach erfolgter Registrierung des Service Owners besteht für diesen die Möglichkeit, seinen Service Provider im ID Austria System zu registrieren. Das System erhält so alle für die Anbindung erforderlichen Informationen – etwa die Verwendung von OIDC oder SAML2, sowie Befugnisse zur Abfrage von bereichsspezifischen Personenkennzeichen [ARB:Web15].

Diese Registrierung erfolgt über das IDA-SPR, welches als Teil des ID Austria Systems betrieben wird und sowohl in Test- als auch in Produktionsumgebungen zur Verfügung

steht. Private Unternehmen können ihren Service Provider über das Unternehmens-Serviceportal verwalten, welches Zugriff auf das IDA-SPR bereitstellt [ARB:Web15].

Im Falle einer Intention seitens eines privaten Service Providers, eine neue Registrierung durchzuführen, ist ein obligatorischer Akkreditierungsprozess zu initialisieren. Im Rahmen dieser Akkreditierung erfolgt die Validierung organisatorischer und technischer Anforderungen. Die Aktivierung der Anwendung kann erst nach erfolgreicher Akkreditierung erfolgen[ARB:Web16].

Nach der erfolgreichen Registrierung des Service Owners kann der Service Provider angelegt werden. Dies erfolgt in mehreren Schritten.

1. Der Service Owner meldet sich im ID Austria System an, klickt auf „*Neuen Service Provider anlegen*“ und gibt Name sowie Unique ID seines Service Providers an.

Service Provider anlegen

Alle Felder mit * sind Pflichtfelder und müssen ausgefüllt werden.
Bitte beachten Sie auch eventuelle Fehlerhinweise ⚠️ .

Name * ?

XY GmbH Test Service

Unique ID * ?

https://demo.xy.at/testservice

- Für OIDC Service Provider: die OIDC Client ID.
- Für SAML2 Direktanbindungen: die EntityID
- MOA Proxy Service Provider: die EntityID des Service Providers.

WICHTIG: Nicht die des MOA Proxys. Diese URL muss mindestens ein Fragezeichen enthalten.

Speichern **Abbrechen**

Abbildung 3.1: Service Provider anlegen – Name und Unique ID (Quelle: [ARB:Web17])

2. Anschließend müssen die technischen Metadaten gesetzt werden. Bei der Nutzung von OIDC muss eine `redirect_uri` angegeben werden.

OIDC SAML

⚠ Weiterleitungsadressen eintragen *

Hinzufügen

Sie müssen mindestens einen Endpunkt hinzufügen.

Sie können maximal 50 Weiterleitungsadressen eintragen.

Achtung: Die URL muss exakt wie hier angegeben auch in dem OIDC Request verwendet werden. Wildcards (*) und Ähnliches werden nicht unterstützt.

☐ OIDC Requested Claims unterstützen

Die Unterstützung von Requested Claims (Siehe auch [OIDC Claims Parameter](#)) nur in Ausnahmefällen notwendig.

☐ Ich benötige ein OIDC Verschlüsselungszertifikat

Speichern Abbrechen

Abbildung 3.2: Technische Metadaten – OIDC Konfiguration (Quelle: *id-austria.gv.at*, [ARB:Web17])

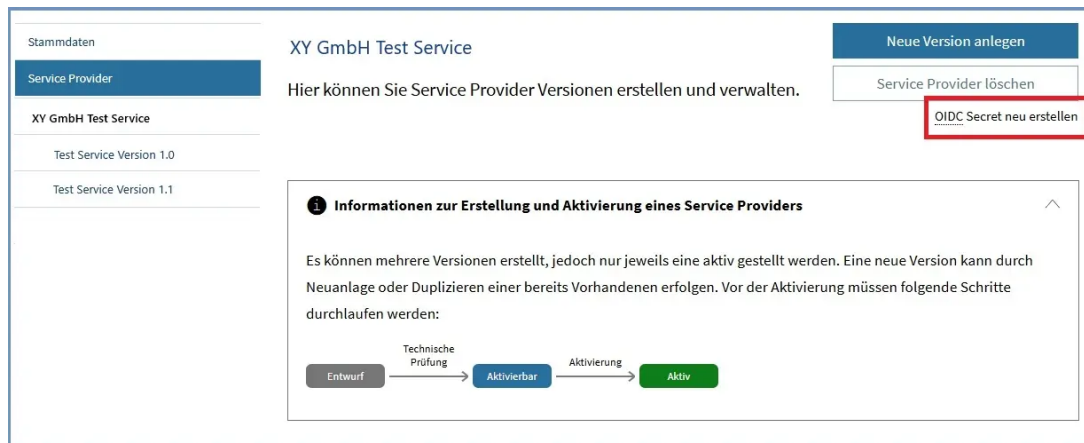
3. Für eine SAML-Anbindung ist die Angabe einer eindeutigen EntityID als gültige URL notwendig, sowie das Signaturzertifikat und die Adresse des SP-Endpoints. Die Konfiguration ist alternativ auch per XML-Datei importierbar.

The screenshot shows the SAML configuration page with the following elements:

- Navigation:** Tabs for 'OIDC' and 'SAML', with 'SAML' selected.
- Hinweis (Note):** A light blue box stating: "Mit dem Button **SAML Daten importieren** können Sie eine **SAML Metadaten XML** Datei hochladen und die darin enthaltenen Daten importieren. Alternativ können Sie die Felder auch manuell ausfüllen."
- SAML Daten importieren:** A button to import SAML data from an XML file.
- EntityID:** A text input field containing "https://demo.xy.at/testservice".
- Signaturzertifikate hochladen:** A section for uploading signature certificates. It includes a text input for the certificate name, a "Durchsuchen" (Browse) button, and a "Hochladen" (Upload) button. Below the input, instructions state: "Wählen Sie eine PEM Datei.", "Die maximale Dateigröße beträgt 1 MB.", "Sie müssen mindestens ein Zertifikat hinzufügen.", and "Sie können maximal 3 Signaturzertifikate hinzufügen."
- Verschlüsselungszertifikat hochladen:** A section for uploading encryption certificates. It includes a text input for the certificate name, a "Durchsuchen" (Browse) button, and a "Hochladen" (Upload) button. Below the input, instructions state: "Wählen Sie eine PEM Datei.", "Die maximale Dateigröße beträgt 1 MB.", "Sie müssen genau ein Zertifikat hinzufügen.", and "Sie können maximal ein Verschlüsselungszertifikat hinzufügen."
- Service Provider Endpunkte eintragen:** A section for adding endpoints. It includes a text input for the endpoint URL (containing "https://mein-serviceprovider.at"), a dropdown for the method (set to "HTTP-POST Methode"), and a "Hinzufügen" (Add) button. Below the input, it states: "Sie können maximal 50 Endpunkte eintragen."
- Eingetragene Endpunkte:** A list of registered endpoints. It shows one entry: "HTTP_POST" with the URL "https://demo.xy.at/testservice/demo".
- Buttons:** "Speichern" (Save) and "Abbrechen" (Cancel) buttons at the bottom.

Abbildung 3.3: Technische Metadaten – SAML Konfiguration (Quelle: *id-austria.gv.at*, [ARB:Web17])

4. Das `client_secret`, welches bei OIDC nur einmal angezeigt wird, sollte sofort kopiert oder gespeichert werden. Eine Neuerstellung ist zwar jederzeit möglich, kann jedoch bis zu 30 Minuten in Anspruch nehmen und in der Zwischenzeit zu Fehlern führen.

Abbildung 3.4: OIDC Secret verwalten (Quelle: *id-austria.gv.at*, [ARB:Web17])

3.5 Anmeldung mit ID Austria via OIDC

Die Anmeldung startet mit der Authentifizierungsanfrage an den Identity Provider. Die Request erfolgt mittels HTTP GET oder HTTP POST auf den Authorization Endpoint des IdP [ARB:Web09].

```

1 GET https://idp.ref.id-austria.gv.at/auth/idp/profile/oidc/authorize
2 ?response_type=code
3 &client_id=https%3A%2F%2Fbeispiel-service.at
4 &redirect_uri=https%3A%2F%2Fbeispiel-service.at%2Fcb
5 &scope=openid+profile+eid
6 &state=1234567890

```

Listing 3.1: Beispiel OIDC Authorization Request (Quelle: *id-austria.gv.at*, [ARB:Web09])

Die Parameter haben dabei folgende Bedeutung:

- `response_type`: Nur der Authorization Code Flow wird von ID Austria akzeptiert, daher muss der Wert `code` angegeben werden.
- `client_id`: Die eindeutige URL im Anwendungskontext, die eine eindeutige Identifikation der Service Provider Applikation ermöglicht.
- `scope`: Definiert die Menge an Benutzerinformationen, die vom IdP angefordert werden. Da die Attributanforderung bei ID Austria über die Service Provider Registrierung erfolgt, wird empfohlen, die Scopes `openid` und `profile` anzufordern.

- `redirect_uri`: Die Callback-URL, an die das ID Austria System die Authentication Response nach erfolgreicher Authentifizierung zurückliefert. Es sind ausschließlich `http(s)`-URLs zulässig.
- `state`: Optionaler, jedoch empfohlener Parameter zum Schutz vor CSRF-Angriffen, der sicherstellt, dass Request und Callback zusammengehören.

Der IdP antwortet dem Client mit der Auswahlmöglichkeit der Authentifizierung – ein Login via ID Austria oder eIDAS ist möglich [ARB:Web09].

The screenshot shows the login interface for oesterreich.gv.at. At the top, it says 'Sicher anmelden mit ID Austria bei oesterreich.gv.at' with language options for Deutsch and English. Below this is the oesterreich.gv.at logo. A notice states that data will be transmitted to oesterreich.gv.at upon login, with a link to the data protection declaration. A link to 'Details zu angeforderten Daten anzeigen' is also present. The main section offers two login methods: 'ID Austria' with a button 'Anmelden mit ID Austria' and a link 'Mehr Info zur ID Austria', and 'EU-Login' with a button 'Anmelden mit nationaler eID'. A description for EU-Login states: 'Melden Sie sich mit Ihrer elektronischen Identität (eID) eines anderen EU-Mitgliedstaates an.'

Abbildung 3.5: Auswahlmöglichkeit der Authentifizierung beim ID Austria Login (Quelle: [ARB:Web09])

Nach erfolgreicher Authentifizierung des Benutzers antwortet der IdP mit einer Authentication Response, die den Authorization Code beinhaltet:

```
1 HTTP/1.1 302 Found
2 Location: https://beispielservice.at/cb
3 code=QXV0aEhhbmRsZXIxfDIwMjA...&state=af0ifjsldkj
```

Listing 3.2: Beispiel Authentication Response (Quelle: [ARB:Web09])

Der Client schickt nun eine POST-Request an den Token-Endpoint des ID Austria Systems. Diese Request enthält den erhaltenen Authorization Code, den Grant Type, die `client_id`, das `client_secret` und die Redirect URI als Formulardaten. Das `client_secret` ist dabei stets verpflichtend – unabhängig davon, ob zusätzlich PKCE verwendet wird oder nicht [ARB:Web09].

```
1 POST https://idp.id-austria.gv.at/auth/idp/profile/oidc/token
2 HTTP/1.1
3
4 code=QXV0aEhhbmRsZXIxfDIwMjA...
5 &grant_type=authorization_code
6 &client_secret=secret
7 &redirect_uri=https://beispielservice.at/cb
8 &client_id=274582323476.beispielservice.at
```

Listing 3.3: Beispiel OIDC Token Request (Quelle: [ARB:Web09])

Nachdem der IdP den Authorization Code erhalten und validiert hat, liefert er die angeforderten Claims mit dem OIDC ID Token in einer Successful Token Response als JSON Web Token. Das ID Austria System signiert den ID Token mit einer JSON Web Signature (JWS). Optional kann der ID Token zusätzlich mithilfe eines Verschlüsselungszertifikates eines ID Austria Service Provider Registrierungssystems verschlüsselt werden. Im Falle einer zusätzlichen Verschlüsselung muss der Token gemäß der OIDC Spezifikation zuerst signiert und anschließend verschlüsselt werden [ARB:Web09].

```
1 {
2   "access_token": "ABlzaGliYm9sZXRoLWRhdGFzZWFsZXItZW5jU....",
3   "token_type": "Bearer",
4   "expires_in": "600",
5   "scope": "openid profile",
6   "id_token": "eyJraWQiOiI4M2EzYzVmZDNlNWQ3YmZjMDI0NDNi...."
7 }
```

Listing 3.4: Beispiel OIDC Successful Token Response (Quelle: [ARB:Web09])

Die Signatur des `id_token` beinhaltet:

- JWS Signaturheader mit Metadaten zur JWS Signatur,
- Payload mit Merkmalen über die Authentifizierung und Attribute des Benutzers,

- JWS Signaturwerte.

```
1 {  
2   "at_hash": "eFoCYhxqGK508kDvqPd1uQ",  
3   "aud": "https://eid.egiz.gv.at/eidpilot_q_oidc",  
4   "auth_time": 1678892052,  
5   "exp": 1678895653,  
6   "iat": 1678892053,  
7   "iss": "https://idp.ref.id-austria.gv.at",  
8   "sub": "IFOQP3T5XYLMSDOQAEGMF52MWGMWBPXN",  
9   "birthdate": "1983-06-04",  
10  "given_name": "XXXOezguer",  
11  "family_name": "XXXTuezekci",  
12  "urn:pvpgovat:oidc.pvp_version": "2.2",  
13  "urn:pvpgovat:oidc.eid_citizen_qaa_eidas_level":  
14    "http://eidas.europa.eu/LoA/high",  
15  "urn:pvpgovat:oidc.bpk": "ZP-MH:KQMY8S19WsmBxrYrYOiFS2VkLyo="
```

Listing 3.5: Dekodiertes Beispiel eines OIDC ID Token Payloads (Quelle: [ARB:Web09])

3.6 Vorteile der ID Austria Integration im Vereinskontext

Ein besonderer Vorteil, der im Vereinskontext nicht ausgelassen werden sollte, ist die passwortlose Authentifizierung. Sie würde Mitgliedern ermöglichen, sich mithilfe von ID Austria einfach und schnell in der App anzumelden oder zu registrieren, ohne sich ein kompliziertes Passwort merken zu müssen – die Anmeldung würde über die externe Öffnung der ID Austria App am Smartphone erfolgen.

Der Verein könnte den Aufwand für eine eigene Authentifizierungsinfrastruktur reduzieren, da die auf OIDC basierende ID Austria bereits hohe Sicherheitsstandards implementiert und als nutzbare Infrastruktur zur Verfügung steht.

Da zentrale Teile der Identitätsfeststellung durch ID Austria übernommen werden, kann das Vertrauen stärker auf den staatlich geprüften Identitätsprovider gestützt werden. Für Nutzer kann dadurch das Risiko unsicherer Authentifizierungsprozesse und eines fehlerhaften Umgangs mit sensiblen Daten reduziert werden. Die Nutzung von ID Austria kann die datenschutzkonforme Verarbeitung unterstützen, da bestimmte sensible Identitätsdaten nicht direkt in der App gespeichert werden müssen. Da jedes Profil eindeutig auf einen Nutzer zurückführbar wäre, könnte das Risiko von Mehrfachkonten reduziert werden, da jeder Nutzer über eine eindeutige, verifizierte Identität verfügen würde.

Da die ID Austria in Österreich bereits weit verbreitet ist, ist es wahrscheinlich, dass viele Mitglieder sie bereits besitzen und beim Umstieg auf die App auf keine besonderen Schwierigkeiten stoßen werden. Neue Nutzer könnten zudem innerhalb der App elektronische Signaturen abgeben. Dies würde es ermöglichen, Beitrittsformulare zu digitalisieren, Datenschutzerklärungen jederzeit abrufbar zu machen sowie Haftungsausschlüsse elektronisch zu signieren.

Durch all diese Optionen könnte der Verwaltungsaufwand für Administratoren reduziert werden. Da der Polzeisportverein einen hohen Anteil an Beamten als Mitglieder hat, erweist sich das *Level High* – die höchste Sicherheitsstufe des EU-Standards – als besonders passend für die verarbeiteten personenbezogenen Vereinsdaten. Auch bei stärkerem Vereinswachstum könnte die Benutzerverwaltung erleichtert werden, da Skalierbarkeit ein Merkmal der ID-Austria-Infrastruktur ist.

Kapitel 4

Analyse und Stakeholder

4.1 Zielgruppen und Stakeholder

Die Vereins-App richtet sich an drei zentrale Zielgruppen. Ziel ist es, die Interaktion mit dem Verein digital zu unterstützen und Verwaltungsprozesse effizienter zu gestalten.

4.1.1 Zielgruppen

Administratoren

Da der Verein nicht profitorientiert arbeitet, sind die derzeitigen Kassierer bzw. Administratoren auch als Polizisten tätig und können daher nicht Vollzeit den Sportverein verwalten. Die Vereins-App soll den Verwaltungsaufwand der Administratoren reduzieren und zentrale Abläufe der Vereinsverwaltung effizienter gestalten.

Anstatt händisch gedruckter Mitgliedskarten, soll der Mitgliedsausweis künftig digital über die App abrufbar sein. Die Freischaltung des Ausweises ist an den Eingang der Zahlung gekoppelt und soll automatisiert erfolgen. Im Gegensatz zum bisherigen Stand, bei dem Administratoren händisch Zahlungseingänge auf dem Vereinskonto überprüfen, abgleichen und einfordern mussten, wird dieser Aufwand künftig deutlich reduziert.

Statt aufwendiger Lagerung von Formularen können Vereinsmitgliedschaft, Datenschutzerklärung, Haftungsausschluss und jede andere Art von Formularen digital gespeichert werden – konstant einsehbar, abrufbereit und digital signierbar. Administratoren

können Mitgliedern Benachrichtigungen über bevorstehende Events senden, Veranstaltungen im Kalender eintragen oder externe Veranstalter einladen und ihnen Berechtigung für Kalendereinträge erteilen. Bei Bedarf können Mitgliedsdaten einfach über eine Abfrage in der Administratoransicht eingesehen oder direkt als CSV-Datei exportiert werden.

Durch die zahlreichen Funktionen soll die Vereins-App dazu beitragen, dass Administratoren künftig weniger Zeit mit der Verwaltung verbringen und mehr Freizeit bzw. Zeit für Vereinsaktivitäten haben.

Mitglieder

Im ursprünglich geplanten System sollten Mitglieder ihr Benutzerkonto über ID Austria erstellen, Formulare elektronisch signieren und jederzeit einsehen können. Dazu sollen sie das Recht auf Änderung oder Löschung der eigenen Daten direkt selbst ausüben können, ohne Termine bei Administratoren vereinbaren zu müssen. Bei einem Umzug beispielsweise kann die Adresse einfach über die App geändert werden.

Durch den Kalender sollen Mitglieder auf Veranstaltungen aufmerksam gemacht werden, ohne diese Informationen im Verein erfragen zu müssen. Zahlungen können sofort und bequem in der App durchgeführt werden, ohne manuelle Zahlungsscheine auszufüllen. Der Mitgliedsausweis soll jederzeit über die App abrufbar sein und kann nicht mehr zu Hause vergessen werden. Falls ein Mitglied Interesse am verpartnerten Onlineshop hat, kann es direkt aus der App heraus die Webseite öffnen.

Externe Veranstalter

Externe Veranstalter profitieren von der Vereins-App, weil sie Mitglieder für ihre Veranstaltungen leichter informieren können. Nach Erteilung der entsprechenden Rechte durch einen Administrator können sie selbstständig Kalendereinträge erstellen und Push-Benachrichtigungen bzw. Erinnerungen an Mitglieder versenden. Dabei können Uhrzeit, Datum, Ort, Dauer sowie Details wie Ausrüstungsempfehlungen eingetragen werden.

4.1.2 Stakeholder

- **Vereinsleitung:** Bestimmt Funktionen, Anforderungen der App und interne Regeln.

- **Mitglieder:** Bestimmen selbst über die Nutzung der App und ihrer Daten.
- **Externe Veranstalter:** Nutzen Funktionen, um Interessenten zu erreichen.
- **Behörden:** Bestimmen Datenschutzrichtlinien und Anforderungen für die elektronische Identität.
- **Staatliche eID-Infrastruktur:** Stellt die technische Grundlage für eine mögliche Authentifizierung mittels IDA zur Verfügung.
- **App Stores:** Haben eigene Richtlinien, die eingehalten werden müssen.
- **Zahlungsanbieter:** Verarbeiten die Zahlung des Mitgliedsbeitrags.

4.1.3 Abgeleitete Anforderungen

Administratoren benötigen einen einfachen Verwaltungszugang mit Überblick über alle relevanten Informationen. Konkret umfasst dies die Befreiung von manueller Verwaltungsarbeit, weniger Lagerungsaufwand für Formulare, automatische Zahlungsabwicklung und -verarbeitung sowie den automatisch generierten Mitgliedsausweis, der nicht mehr händisch gedruckt werden muss.

Mitglieder stellen die Anforderung eines sicheren und einfachen Logins – diese Anforderung sollte ursprünglich durch ID Austria erfüllt werden. Darüber hinaus sollen persönliche Daten DSGVO-konform gespeichert und jederzeit änderbar sein. Die Selbstbestimmung über eigene Daten sowie die Einsicht von Formularen sollen über die App möglich sein. Nachvollziehbarkeit über den Zugriff auf persönliche Daten wird durch das Logging der Administratoraktionen gewährleistet.

4.2 Use Cases

Die folgenden Use Cases beschreiben den ursprünglich geplanten Soll-Zustand der Vereins-App. Aufgrund der Scope-Reduktion wurde die ID-Austria-Integration im umgesetzten System jedoch nicht vollständig realisiert.

Als Use Cases bezeichnet man typische Abläufe, die Zielgruppen durchgehen. Um einen Überblick und ein Gefühl für die verschiedenen Use Cases der Vereinsapp zu geben, wurden 5 Muster-Use-Cases ausgewählt, welche die funktionalen Anforderungen der Vereinsapp praxisnah zeigen.

4.2.1 Use Case 1 – Konzeptionelle Registrierung mit ID Austria

Wenn sich Benutzer im ursprünglich geplanten System mit ID Austria einmalig registrieren möchte, muss er nach dem Herunterladen die App öffnen und auf „*Registrierung mit ID Austria*“ klicken. Der Nutzer würde weitergeleitet und müsste sich mit der ID Austria verifizieren. Nach erfolgreich angelegtem Konto würde er beschränkten Zugriff auf die App erhalten. Sobald seine Zahlung eingegangen wäre, würde seine Mitgliedschaft aktiviert und sein Mitgliedsausweis freigeschaltet werden.

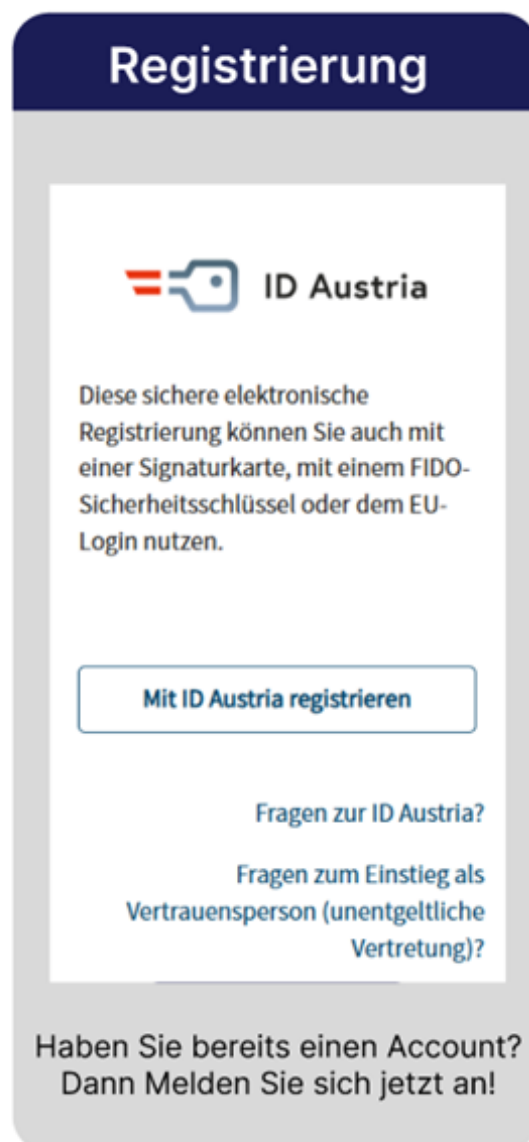


Abbildung 4.1: Registrierung mit ID Austria

Der digitale Mitgliedsausweis ist in vier Zuständen verfügbar:



Abbildung 4.2: Ausweis – Hochformat



Abbildung 4.3: Ausweis – Querformat Vorderseite



Abbildung 4.4: Ausweis – Querformat Rückseite



Abbildung 4.5: Ausweis – Gesperrt

4.2.2 Use Case 2 – Konzeptionelle Anmeldung mit ID Austria

Sollte der Nutzer die Registrierung im ursprünglich geplanten System bereits durchgeführt haben und sich erneut anmelden wollen, öffnet er die App und drückt auf „Anmeldung mit ID Austria“. Nach erfolgreicher Weiterleitung und Verifikation durch ID Austria würde er sich in sein bestehendes Konto anmelden können.. Sollte der Nutzer kein Konto besitzen und trotzdem versuchen sich anzumelden, würde er darauf hingewiesen, dass unter seiner ID Austria kein Konto registriert ist und er sich zunächst registrieren müsste.

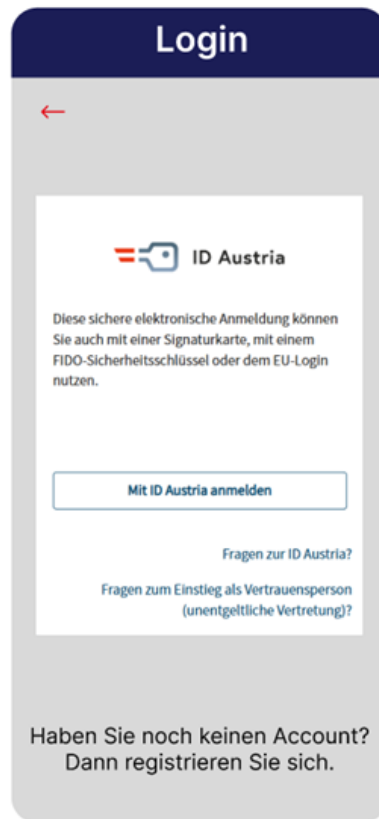


Abbildung 4.6: Anmeldung mit ID Austria

4.2.3 Use Case 3 – Konzeptionelle digitale Signatur mit ID Austria

Wenn ein angemeldeter Benutzer im ursprünglich geplanten System sein Konto aktivieren wollte, hätte er vor der Zahlung Dokumente wie Haftungsausschlüsse signieren müssen. Diese Signaturen hätte er mithilfe der digitalen Signatur, die ID Austria bereitstellt, durchführen können. Die rechtlich gültige Unterschrift würde anschließend gespeichert und wäre jederzeit über die Vereins-App abrufbar.

4.2.4 Use Case 4 – Kalender und Veranstaltungen

Wenn ein externer Veranstalter eine neue Veranstaltung eintragen möchte, meldet er sich regulär in der App an. Ein Administrator muss ihm zunächst die Rechte gewähren, Veranstaltungen in den Terminkalender einzutragen und Push-Benachrichtigungen an

Mitglieder zu versenden. Nach Erhalt dieser Rechte kann der externe Veranstalter einen Kalendereintrag erstellen, der für alle Mitglieder sichtbar ist.

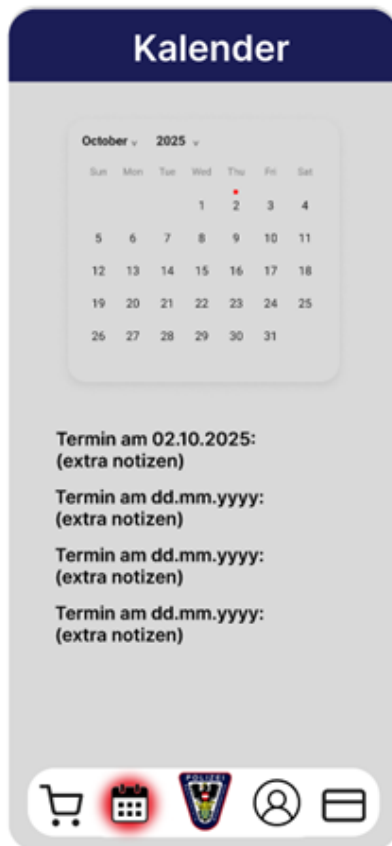


Abbildung 4.7: Kalenderansicht Mitglieder

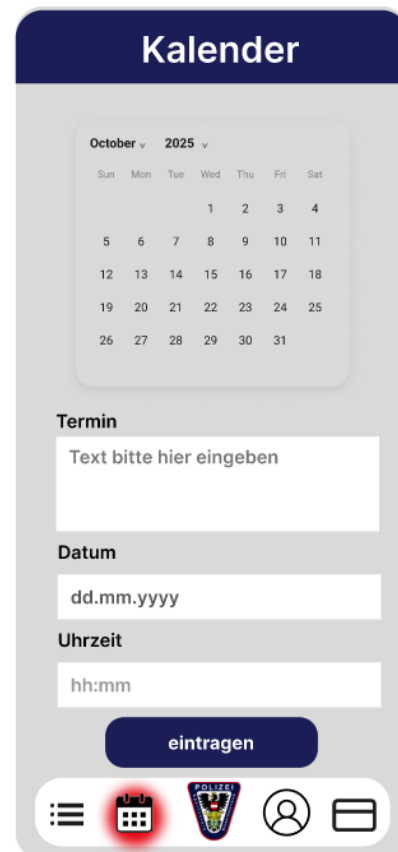


Abbildung 4.8: Kalendereintrag erstellen

4.2.5 Use Case 5 – Zahlungsabwicklung

Wenn ein angemeldeter Benutzer seine Zahlung durchführen möchte, um seine Mitgliedschaft zu beginnen oder zu verlängern, navigiert er zur Zahlungsmaske. Dort wählt er die gewünschte Zahlungsmethode aus, sieht den fälligen Betrag, bestätigt die Zahlung und wird nach erfolgreichem Zahlungseingang automatisch als aktives Mitglied betrachtet.

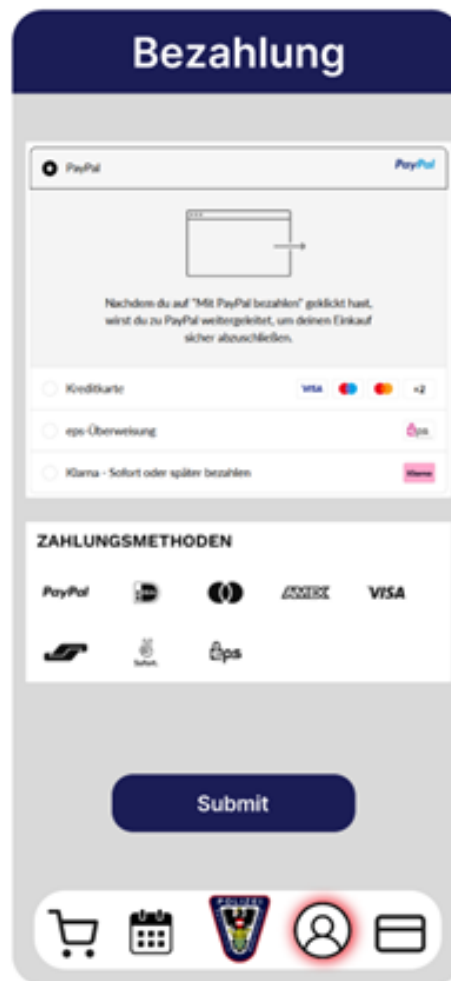


Abbildung 4.9: Zahlungsseite

4.3 Sicherheitsanforderungen

Für einen Polizeisportverein, dessen Mitglieder häufig Polizisten sind, spielt Sicherheit eine große Rolle. Um die Sicherheit sensibler Nutzerdaten in der App zu gewährleisten, müssen mehrere Grundvoraussetzungen erfüllt werden.

- **Authentifizierung:** Als Authentifizierungsmethode war ursprünglich ID Austria vorgesehen, um den Mitgliedern einen sicheren Login- bzw. Registrierungspro-

zess zu ermöglichen. Eine detaillierte Erklärung über die Funktionalitäten der ID Austria findet sich in *siehe Kapitel 3*. Die passwortlose Authentifizierung mit ID Austria hätte in der App für Schutz vor Passwort-Leaks geboten und die allgemeine Sicherheit der App gestärkt.

- **Verschlüsselung:** Die Kommunikation zwischen der App und dem Backend erfolgt in der Produktionsumgebung über TLS. Mithilfe eines Zertifikates wird das Abhören und die Manipulation der Kommunikation verhindert. Ohne TLS riskiert man Man-in-the-Middle-Angriffe.
- **Rollenbasierter Zugriff:** In der App wird zwischen Administratoren und normalen Mitgliedern unterschieden. Administratoren haben die Berechtigung Kalendereinträge und Push-Benachrichtigungen zu erstellen, auf Rollenverwaltung und können bestimmte Nutzerdaten, die für die Verwaltung notwendig sind, einsehen. Mitglieder selbst können den Kalender abrufen, Push-Benachrichtigungen erhalten und auf ihre eigenen Daten über z.B. Ausweise zugreifen.
- **Protokollierung:** Sicherheitsrelevante Ereignisse werden DSGVO-konform geloggt. Darunter fallen der Eingang von Zahlungen, Statusänderungen von Benutzern sowie der Zugriff auf und Export von Nutzerdaten. Logging spielt vor allem dann eine Rolle, wenn Nachvollziehbarkeit von Behörden wegen Datenschutzverletzungen oder Missbrauchs gefordert wird.

Diese vier Punkte bilden die Sicherheitsanforderungen der Vereins-App des Polizeisportvereins.

4.4 Datenschutz und DSGVO

Da in der Vereins-App personenbezogene Daten verarbeitet werden, müssen die Grundsätze des Artikel 5 DSGVO eingehalten werden [ARB:Web19].

Die Umsetzung der DSGVO in der Vereins-App sieht folgendermaßen aus:

- **Zweckbindung:** Die Daten der Nutzer, die in der Datenbank der Vereins-App gespeichert werden, werden ausschließlich für die Vereinsverwaltung verwendet. Da im Sinne einer Scope-Reduktion die ID Austria-Implementierung weggefallen ist, werden in der Produktion die E-Mail-Adresse, der Passwort-Hash und der Salt gespeichert. Von jedem Benutzer werden Vorname, Nachname, Geburtsdatum, Adresse, Telefonnummer und Rolle gespeichert. Bei Mitgliedern, die Polizisten sind, werden zusätzlich die Dienstnummer und die Region erfasst. Das

Erstellungsdatum sowie das Datum der letzten Änderung werden ebenfalls gespeichert.

- **Datenminimierung:** Die App erhebt ausschließlich für den Verein notwendige Daten und hält damit den Grundsatz der Datenminimierung ein.
- **Speicherbegrenzung:** Nutzerdaten werden im Rahmen eines Soft Deletes unkenntlich gemacht, sobald der Nutzer sein App-Profil löscht. Die Löschung erfolgt als *Soft Delete* – sensible Nutzerdaten werden dabei entfernt, der leere Nutzereintrag verbleibt jedoch für Logging-Zwecke in der Datenbank. Das Datum der Löschung wird im Datenbankfeld `erased_at` gespeichert. Mit der Löschung des App-Profiles wird gleichzeitig der Austritt aus der Vereinsmitgliedschaft durchgesetzt.
- **Integrität und Vertraulichkeit:** Mithilfe des rollenbasierten Zugriffs und des TLS-Protokolls wird die Integrität der Nutzerdaten garantiert.
- **Rechenschaftspflicht:** Durch das Logging jedes Zugriffs auf Nutzerdaten wird die Rechenschaftspflicht erfüllt. Die Logs können jederzeit von Administratoren eingesehen werden.

Kapitel 5

Architektur und Implementierung

In diesem Kapitel wird die technische Architektur und die Implementierung des Systems, der Authentifizierung, des rollenbasierten Zugriffs, der Datenbankmodelle, des Mitgliedsausweises und die geplante Integration von ID Austria näher beschrieben. Es wird noch einmal vermerkt, dass die tatsächliche Implementierung von ID Austria wegen Ressourcenknappheit trotz Konzipierung aus dem Scope gestrichen wurde. Stattdessen wurde eine E-Mail-Passwort-Authentifizierung implementiert, die mit Salting arbeitet.

5.1 Systemarchitektur

Für das Frontend der App wird Flutter verwendet. Flutter bietet den Vorteil, auf mehreren Betriebssystemen gleichzeitig kompilierbar zu sein – die App kann somit sowohl auf Android- als auch auf iOS-Geräten angeboten werden. Die App kommuniziert über eine REST API mit dem Java Spring Backend, welches Anfragen verarbeitet, Geschäftslogik implementiert und die Authentifizierung mithilfe von JSON Web Tokens durchführt. Das Backend greift auf die Datenbank zu, die auf PostgreSQL läuft. PostgreSQL ist für diese App ideal geeignet, da es ein bewährtes relationales Datenbanksystem ist und sich gut für strukturierte Vereinsdaten eignet.



Abbildung 5.1: Systemarchitektur der Vereins-App

5.2 Datenbankmodell

Das Datenmodell besteht aus insgesamt 11 Tabellen, die sich in drei Gruppen aufgliedern: Benutzerverwaltung, Vereinsaktivitäten sowie Logging und Audit.

Gruppe 1 – Benutzerverwaltung

- **Users:** Die zentrale Tabelle, auf die alle anderen referenzieren. Sie besitzt das `role_enum`, welches zwischen `CIVILIAN` und `POLICE_OFFICER` unterscheidet. Dies ist wichtig, da Polizisten bei der Registrierung ihre `service_number` angeben müssen und aktive Polizisten statt des normalen Beitrags von 30 € einen rabattierten Beitrag von 20 € zahlen. Für den DSGVO-konformen Soft Delete wird `erased_at` gespeichert – dieses Datum wird nur gesetzt, falls das Mitglied aus dem Verein austritt oder seine Nutzerdaten in der App löscht. Die Felder `email`, `password_hash` und `salt` sind wegen der Scope-Reduktion die zentrale Authentifizierungsmethode.
- **Region:** Eine einfache Lookup-Tabelle für Polizeiregionen. Ein User hat eine Region, eine Region kann jedoch mehrere User haben.
- **Locality:** Wohnort mit PLZ und Stadt. Jeder User hat genau einen Wohnort.
- **Admin:** Die Admin-Tabelle erweitert die Users-Tabelle um die Boolean-Felder `calendar_flag`, `push_flag`, `view_flag` und `new_admin_flag`, die zur Zu-

weisung von Administratorberechtigungen dienen. Nur User, die in dieser Tabelle eingetragen sind, werden als Administratoren behandelt.

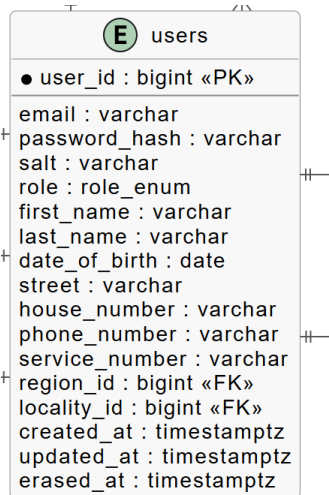


Abbildung 5.2: User Tabelle

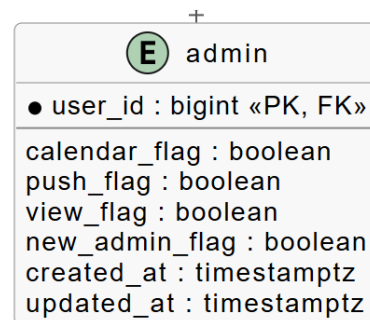


Abbildung 5.3: Admin Tabelle

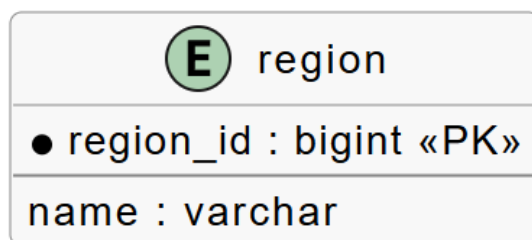


Abbildung 5.4: Region Tabelle

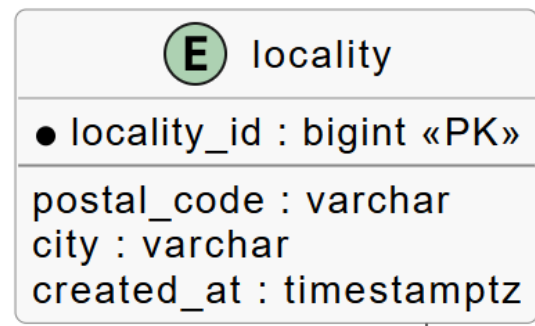


Abbildung 5.5: Locality Tabelle

Gruppe 2 – Vereinsaktivität

- **Payment:** Speichert Mitgliedsbeitragszahlungen. Ob die Mitgliedschaft aktiv ist, wird über das Feld `valid_until` bestimmt. Das `membership_status_enum` unterscheidet zwischen regulären Mitgliedern und Polizisten. Das `payment_method_enum` registriert die verwendete Zahlungsmethode. Doppelzahlungen werden durch einen Unique Constraint auf `user_id + year` verhindert.
- **Calendar_event:** Speichert Veranstaltungen im Kalender. Administratoren mit der `calendar_flag` dürfen Kalendereinträge erstellen. Der eintragende Administrator wird im Feld `created_by` gespeichert.

- **Push_notification:** Speichert Push-Benachrichtigungen, die Administratoren mit der `push_flag` versenden können. Der erstellende Administrator wird ebenfalls gespeichert. Das Feld `audience_json` ermöglicht es als JSONB, beliebige Filterkriterien des Administrators abzuspeichern.

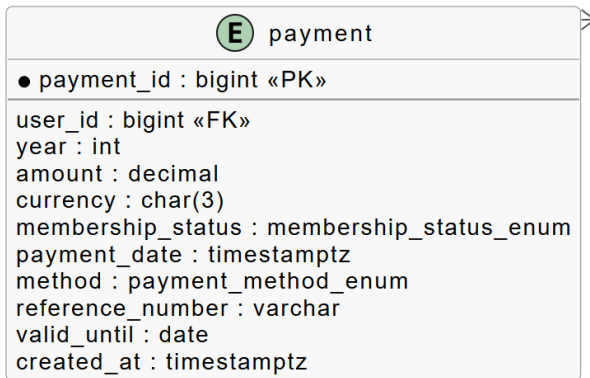


Abbildung 5.6: Payment Tabelle

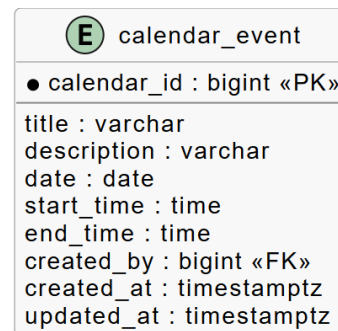


Abbildung 5.7: Calendar Event Tabelle

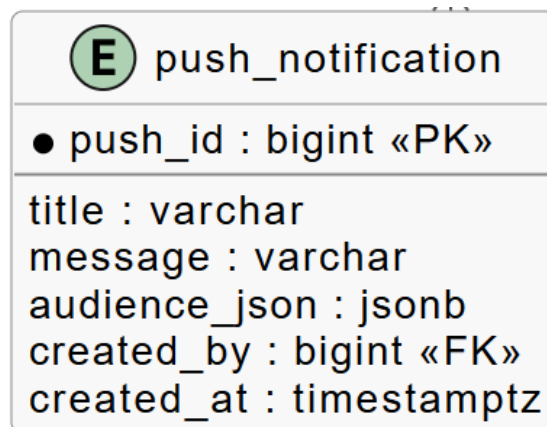


Abbildung 5.8: Push Notification Tabelle

Gruppe 3 – Logging und Audit

- **Data_access_event:** Protokolliert jeden Zugriff eines Administrators auf Nutzerdaten. Das `action_enum` unterscheidet zwischen `view` und `download`. Angewendete Filter werden im Feld `filter_json` gespeichert. Der Administrator ist verpflichtet, ein `comment` abzugeben, in dem er klar begründen muss, warum er die Daten eingesehen oder exportiert hat.
- **Data_access_subject:** Ein zusammengesetzter Primary Key aus `event_id` und `user_id`, der einen Snapshot zum Zeitpunkt des Zugriffs speichert. Die Felder

role_snapshot, membership_status_snapshot und paid_snapshot sind wichtig, da sich Nutzerdaten später ändern können. Bei gelöschtem Konto verweist der Foreign Key user_id auf den Soft Deleted User.

- **Admin_rights_audit:** Protokolliert alle Änderungen an Admin-Rechten. Das event_type_enum kann PROMOTE_TO_ADMIN, REVOKE_ADMIN oder FLAGS_CHANGED annehmen. Die genauen Änderungen werden im Feld changes_json im JSON-Format abgespeichert. Die Felder actor_admin_id und target_user_id zeigen, wer wen bearbeitet hat.

E data_access_event
● event_id : bigint «PK»
admin_id : bigint «FK» action : action_enum filter_json : jsonb comment : text result_count : int created_at : timestampz

Abbildung 5.9: Data Access Event Tabelle

E admin_rights_audit
● event_id : bigint «PK»
actor_admin_id : bigint «FK» target_user_id : bigint «FK» event_type : admin_event_type_enum changes_json : jsonb reason : text request_id : varchar created_at : timestampz

Abbildung 5.10: Admin Tabelle

E data_access_subject
● event_id : bigint «PK, FK» ● user_id : bigint «PK, FK»
included_at : timestampz role_snapshot : role_enum membership_status_snapshot : membership_status_enum paid_snapshot : boolean paid_year_snapshot : int notes : text

Abbildung 5.11: Region Tabelle

5.3 Authentifizierung

Da die ID Austria Implementierung von Anfang an kein Muss-Ziel war, wurde diese im Rahmen der Scope-Reduktion wegen Ressourcenmangels als erstes gestrichen. Stattdessen wurde eine E-Mail-Passwort-Authentifizierung gewählt.

5.3.1 Passwort-Hashing mit Salt

Um Passwörter noch sicherer als nur in gehashter Form zu speichern, werden Salts verwendet. Salts sorgen dafür, dass Rainbow-Table-Angriffe nicht möglich werden, da dem Passwort vor dem Hashing-Prozess ein zufälliger String angehängt wird. Das Salt wird im Feld `salt` des Usermodells gespeichert, der BCrypt-Hash im Feld `password_hash`.

5.3.2 JWT-Generierung

JSON Web Token wird als Authentifizierungstoken verwendet. Nach erfolgreichem Login wird ein Token generiert und an den Client zurückgegeben. Der Client muss jeden weiteren Zugriff auf das Backend mit diesem JWT authentifizieren.

5.3.3 JWT Service

Die JWT-Generierung wird in der Polizeisportvereins-App mit einem JWT-Service durchgeführt. Der Service erstellt einen eine Woche lang gültigen Token. Der Nutzer muss dafür in der Datenbank enthalten sein.

Im ersten Schritt wird die aktuelle Mitgliedschaft des Nutzers geprüft:

```
1 private static final long EXPIRY_TIME = 604_800L; // Sekunden
2
3 LocalDate today = LocalDate.now();
4 Optional<Payment> latestPaymentOpt =
5     paymentRepository
6         .findTopByUserUserIdOrderByValidUntilDesc(user.getUserId());
7
8 LocalDate membershipValidUntil = null;
9 boolean membershipActive = false;
10 if (latestPaymentOpt.isPresent()) {
11     Payment latestPayment = latestPaymentOpt.get();
```

```
12     membershipValidUntil = latestPayment.getValidUntil();
13     membershipActive = !today.isAfter(membershipValidUntil);
14 }
15
16 String membershipType = null;
17 if (membershipActive) {
18     membershipType = (user.getRole() == Role.POLICE_OFFICER)
19         ? "ausserordentliches Mitglied"
20         : "ordentliches Mitglied";
21 }
```

Listing 5.1: Mitgliedschaftsprüfung im JWT Service

Anschließend werden die Admin-Flags geprüft. Wenn der User in der Admin-Tabelle existiert, werden die Flags aus der Datenbank gelesen und in den JWT geschrieben:

```
1 Optional<Admin> adminOpt = adminRepository.findById(user.getUserId());
2 if (adminOpt.isPresent()) {
3     Admin admin = adminOpt.get();
4     isAdmin = true;
5     calendarFlag = admin.getCalendarFlag();
6     pushFlag = admin.getPushFlag();
7     viewFlag = admin.getViewFlag();
8     newAdminFlag = admin.getNewAdminFlag();
9 }
```

Listing 5.2: Admin-Flag Prüfung im JWT Service

Im letzten Schritt wird der Claim zusammengebaut. Die Mitgliedschaftsart und der Admin-Status stehen immer im JWT – die Admin-Flags sind nur enthalten, falls der User tatsächlich ein Administrator ist:

```
1 JwtClaimsSet.Builder claimsBuilder = JwtClaimsSet.builder()
2     .issuer("self")
3     .issuedAt(now)
4     .expiresAt(now.plus(EXPIRY_TIME, SECONDS))
5     .subject(email)
6     .claim("membership_active", membershipActive)
7     .claim("is_admin", isAdmin);
8
9 if (isAdmin) {
10     claimsBuilder
11         .claim("admin_calendar_flag",
12             calendarFlag != null ? calendarFlag : Boolean.FALSE)
13         .claim("admin_push_flag",
14             pushFlag != null ? pushFlag : Boolean.FALSE)
15         .claim("admin_view_flag",
16             viewFlag != null ? viewFlag : Boolean.FALSE)
17         .claim("admin_new_admin_flag",
18             newAdminFlag != null ? newAdminFlag : Boolean.FALSE);
19 }
```

Listing 5.3: JWT Claim Erstellung

5.3.4 Security Config

Das JWT-Secret wird separat aus der `application.yml` geladen und als HmacSHA256-Schlüssel verwendet. Das JWT-Secret kann jederzeit geändert werden und ist nie hardcoded im Code zu finden. Hash-based Message Authentication Code – kurz HMAC – ist ein Message Authentication Code, der eine Hash-Funktion mit einem geheimen Schlüssel kombiniert, um die Integrität und Authentizität des Tokens sicherzustellen [ARB:Web20].

```
1 @Value("${security.jwt.secret}")
2 private String jwtSecret;
3
4 @Bean
5 public SecretKey jwtSecretKey() {
6     return new SecretKeySpec(
7         jwtSecret.getBytes(StandardCharsets.UTF_8),
8         "HmacSHA256"
9     );
10 }
```

Listing 5.4: JWT Secret Konfiguration

Der einzige öffentliche Endpoint ist `/api/auth/` – alle anderen Endpoints sind nur mit einem gültigen JWT erreichbar. Da der JWT im Header und nicht als Cookie übertragen wird, ist Cross-Site-Request-Forgery (CSRF) deaktiviert [ARB:Web21].

```
1 @Bean
2 public SecurityFilterChain securityFilterChain(HttpSecurity http)
3     throws Exception {
4     http
5         .cors(Customizer.withDefaults())
6         .csrf(csrf -> csrf.disable())
7         .authorizeHttpRequests(auth -> auth
8             .requestMatchers(HttpMethod.OPTIONS, "**").permitAll()
9             .requestMatchers("/api/auth/**").permitAll()
10            .anyRequest().authenticated()
11        )
12        .oauth2ResourceServer(oauth -> oauth.jwt(Customizer.withDefaults()))
13        ;
14     return http.build();
15 }
```

Listing 5.5: Security Filter Chain Konfiguration

Der Flutter-Client sendet den JWT bei jedem Request im Authorization-Header:

```
1 headers: {  
2   'Authorization': 'Bearer $token',  
3   'Content-Type': 'application/json',  
4 }
```

Listing 5.6: JWT Header im Flutter Client

5.4 Rollenbasierter Zugriff

Um zu unterscheiden, wer ein normaler App-Benutzer ist und wer ein Administrator ist, wird rollenbasierter Zugriff genutzt. Administratoren können dabei vier verschiedene Berechtigungen haben.

5.4.1 Admin-Flags im JWT

Die vier Flags `calendar_flag`, `push_flag`, `view_flag` und `new_admin_flag` werden aus der Admin-Tabelle gelesen und in den JWT geschrieben. Das Frontend liest den JWT ein und zeigt oder versteckt entsprechende Funktionen.

```
1 boolean isAdmin = false;  
2 Boolean calendarFlag = null;  
3 Boolean pushFlag = null;  
4 Boolean viewFlag = null;  
5 Boolean newAdminFlag = null;  
6  
7 Optional<Admin> adminOpt = adminRepository.findById(user.getUserId());  
8 if (adminOpt.isPresent()) {  
9   Admin admin = adminOpt.get();  
10  isAdmin = true;  
11  calendarFlag = admin.getCalendarFlag();  
12  pushFlag = admin.getPushFlag();  
13  viewFlag = admin.getViewFlag();  
14  newAdminFlag = admin.getNewAdminFlag();  
15 }  
16 if (isAdmin) {  
17   claimsBuilder  
18     .claim("admin_calendar_flag",  
19       calendarFlag != null ? calendarFlag : Boolean.FALSE)  
20     .claim("admin_push_flag",  
21       pushFlag != null ? pushFlag : Boolean.FALSE)  
22     .claim("admin_view_flag",  
23       viewFlag != null ? viewFlag : Boolean.FALSE)
```

```
24     .claim("admin_new_admin_flag",  
25           newAdminFlag != null ? newAdminFlag : Boolean.FALSE);  
26 }
```

Listing 5.7: Admin-Flags aus der Datenbank in den JWT schreiben

5.4.2 Fallbeispiel: Mitgliedsausweis abrufen

Der Nutzer hat sich bereits angemeldet und möchte nun seinen Ausweis anzeigen. Der Ablauf gestaltet sich dabei folgendermaßen:

1. Das Frontend sendet eine GET-Request mit dem JWT des Nutzers an den `/api/ausweis/me` Endpoint.

```
1 @GetMapping("/me")  
2 public ResponseEntity<Ausweis> getMyAusweis(  
3     @AuthenticationPrincipal Jwt jwt) {  
4     Ausweis ausweis = ausweisService.buildAusweisFromJwt(jwt);  
5     return ResponseEntity.ok(ausweis);  
6 }
```

Listing 5.8: Ausweis Controller Endpoint

2. Der Ausweis-Controller erhält die Anfrage und leitet den JWT an den Ausweis-Service weiter.
3. Der Ausweis-Service baut den Ausweis aus dem JWT zusammen und überprüft dabei, ob die Mitgliedschaft noch gültig ist. Wenn die Mitgliedschaft ungültig ist, wird `firstName` auf „*abgelaufen*“ gesetzt und alle restlichen Werte werden annulliert.

```
1 public Ausweis buildAusweisFromJwt(Jwt jwt) {  
2     String email = jwt.getSubject();  
3     User user = userRepository.findByEmail(email)  
4         .orElseThrow(() ->  
5             new IllegalStateException("User not found: " + email));  
6  
7     String firstName = jwt.getClaim("first_name");  
8     String lastName = jwt.getClaim("last_name");  
9     String membershipType = jwt.getClaim("membership_type");  
10    String validUntilStr = jwt.getClaim("membership_valid_until");  
11  
12    // Wenn abgelaufen oder kein validUntil -> abgelaufen  
13    if (validUntil == null || today.isAfter(validUntil)) {  
14        ausweis.setFirstName("abgelaufen");  
15        ausweis.setMembershipType(null);  
16    }
```

```
16 |     }  
17 |  
18 |     return ausweis;  
19 | }
```

Listing 5.9: Ausweis Service – Mitgliedschaft validieren

4. Der Controller gibt den Ausweis an das Frontend zurück.
5. Das Frontend überprüft, ob der Ausweis gültig ist. Im Falle eines abgelaufenen Ausweises sieht der Nutzer keine Ausweisansicht, sondern eine gesperrte Ansicht mit einer Zahlungserinnerung, um seine Mitgliedschaft wieder zu aktivieren. Verfügt der Nutzer über eine aktive Mitgliedschaft, wird der Ausweis angezeigt.

5.5 Geplante ID Austria Integration

Im Szenario der Beibehaltung von ID Austria als Authentifizierungsmethode wären weder ein `password_hash` noch ein `salt` im User-Model notwendig gewesen.

5.5.1 Authentifizierung

Statt einer E-Mail-Adresse und eines Passworts hätte der Nutzer auf „*Login mit ID Austria*“ gedrückt und wäre zum ID Austria Identity Provider weitergeleitet worden. Es hätte der OIDC Authorization Code Flow stattgefunden, woraufhin der Identity Provider den Token zurückgesendet hätte. Dieser Flow wird in *siehe Kapitel 2.2.3* genauer beschrieben.

5.5.2 User-Model

Die bestehenden Felder `password_hash` und `salt` zur Identitätsbestimmung wären nicht notwendig gewesen, da der Nutzer über das `sub`-Claim im ID Austria Token eindeutig identifizierbar gewesen wäre.

5.5.3 JWT

Das ID Austria ID Token hätte als Basis für einen geeigneten JSON Web Token gedient. Die Claims hätten direkt aus dem ID Token gelesen und in den eigenen JWT übernommen werden können.

5.5.4 Sicherheitsvorteile

Da eine passwortlose Authentifizierung ermöglicht worden wäre, hätte die Datenbank keine Passwort-Hashes enthalten müssen. Das Risiko klassischer Passwort-Leaks wäre damit deutlich reduziert worden. Die eIDAS-Sicherheitsstufe *Level High* hätte für die Authentifizierung ein hohes Vertrauensniveau ermöglicht[ARB:Web13], und Mehrfachkonten wären durch den eindeutigen `sub`-Claim verhindert worden.

Kapitel 6

Fazit

6.1 Fazit Barsam Aghajani Rizi

Im Rahmen dieser Diplomarbeit wurde untersucht, welche Rolle ID Austria als sichere Authentifizierungsmethode für eine mobile Vereinsanwendung spielen kann. Dabei konnte gezeigt werden, dass moderne Verfahren des digitalen Identitätsmanagements, insbesondere OAuth 2.0 und OpenID Connect, eine wichtige Grundlage für sichere und benutzerfreundliche Anmeldelösungen bilden. Gerade im Vereinskontext bietet ID Austria großes Potenzial, da sie eine passwortlose Authentifizierung, eine eindeutige Identifizierung von Nutzern sowie Vorteile in Bezug auf Datenschutz und Vertrauenswürdigkeit ermöglicht.

Zusätzlich wurden die Anforderungen an eine Vereins-App analysiert und die bestehende Systemarchitektur der entwickelten Anwendung dargestellt. Die Arbeit zeigt, dass bereits in der aktuellen Umsetzung wichtige Sicherheitsmechanismen berücksichtigt wurden, darunter TLS, rollenbasierter Zugriff, Logging und eine JWT-basierte Zugriffskontrolle. Damit wurde eine technische Grundlage geschaffen, auf der eine spätere Erweiterung prinzipiell möglich ist.

Gleichzeitig hat die Arbeit auch deutlich gemacht, dass die vollständige praktische Implementierung von ID Austria im gegebenen Projektumfang nicht realisiert werden konnte. Aufgrund von Ressourcenknappheit und Scope-Reduktion wurde stattdessen eine E-Mail-Passwort-Authentifizierung mit Salt umgesetzt. Die geplante ID-Austria-Integration blieb daher auf konzeptioneller Ebene, wodurch die Arbeit weniger eine abgeschlossene Implementierung als vielmehr eine fachliche und architektonische Vorbereitung dieser Authentifizierungsmethode darstellt.

Zusammenfassend zeigt die Diplomarbeit, dass ID Austria für eine Vereins-App eine sinnvolle und zukunftsfähige Lösung darstellt, insbesondere wenn hohe Anforderungen an Sicherheit, Datenschutz und Benutzerfreundlichkeit bestehen. Die Ergebnisse der Arbeit liefern damit eine fundierte Grundlage für eine spätere praktische Integration und zeigen zugleich, welche technischen und organisatorischen Voraussetzungen dafür berücksichtigt werden müssen.

6.2 Fazit Christian Langsteiner

Das Ziel dieser Arbeit war es, den Begriff „Responsive Webdesign“ zu durchleuchten, seine Entstehung zu verstehen und praktische Wege zu zeigen, wie man Websites für alle Geräte zugänglich macht. Am Anfang stand die Beobachtung: Menschen nutzen das Internet heute vor allem über Smartphones und Tablets, aber auch weiterhin am Desktop. Statt für jedes Gerät eine eigene Version zu erstellen, braucht es einen Ansatz, der flexibel ist und sich anpasst.

Deshalb haben wir uns zuerst die Geschichte des Responsiven Webdesigns angeschaut. Ethan Marcotte prägte den Begriff und öffnete damit eine neue Sichtweise: Webseiten sind keine starren Konstruktionen mehr, sondern reagierende Systeme. Sie müssen sich so verändern können, wie es der Bildschirm, die Eingabeform und die Situation der Nutzer verlangen. Aus diesem Gedanken heraus haben sich drei Strategien entwickelt – Graceful Degradation, Progressive Enhancement und Mobile First – die jeweils ihren eigenen Schwerpunkt setzen. Graceful Degradation startet bei einer funktionsreichen Variante und passt nach unten an, Progressive Enhancement startet bei einer schlanken Basis und fügt Funktionen hinzu, Mobile First stellt mobile Geräte in den Fokus. In der Praxis hat sich gezeigt, dass keine dieser Strategien allein den Schlüssel bildet; vielmehr entscheidet das Projekt, wann welcher Ansatz sinnvoll ist.

Ein weiteres Ergebnis der Arbeit ist die Erkenntnis, dass der Prozess der Webgestaltung nicht mehr linear verläuft. Während man früher erst Layouts entwarf und dann programmierte, arbeitet man heute iterativ: Prototypen werden früh erstellt, getestet und gemeinsam weiterentwickelt. Das fördert die Zusammenarbeit zwischen Designern und Entwicklern und sorgt dafür, dass Fehler schneller erkannt und behoben werden können. Benutzerfreundlichkeit und Barrierefreiheit müssen von Anfang an mitgedacht werden; das betrifft die Wahl der Schriftgröße ebenso wie die Struktur des Menüs oder die Performance der Seite.

Bei der praktischen Umsetzung wird klar, wie vielfältig die Gestaltungsmöglichkeiten sind. Moderne CSS-Techniken wie Grid und Flexbox machen flexible Layouts möglich. Bilder werden über srcset in verschiedenen Auflösungen ausgeliefert, um auf

Retina-Displays gut auszusehen und trotzdem Datenvolumen zu sparen. Navigationen lassen sich als einfache, sich selbst umbrechende Leisten, als Hamburger-Menüs oder als Off-Canvas-Menüs realisieren. Jede dieser Varianten hat Stärken und Schwächen, je nachdem, wie viele Navigationspunkte vorhanden sind und wie vertraut die Nutzer damit sind. Auch die Typografie kann nicht mehr pauschal über Pixel definiert werden; relative Einheiten wie `em` und `rem` sorgen dafür, dass Schriften auf verschiedenen Geräten gut lesbar bleiben und sich an die Einstellungen des Nutzers anpassen.

Die Auseinandersetzung mit dem Framework Flutter hat gezeigt, dass die Ideen des Responsiven Webdesigns auch abseits der klassischen Webentwicklung Anwendung finden. Widgets wie `LayoutBuilder` oder `MediaQuery` helfen dabei, Oberflächen dynamisch zu gestalten. Außerdem können Bildassets in unterschiedlichen Größen bereitgestellt werden, sodass die passende Variante automatisch geladen wird.

Am Ende lässt sich sagen: Responsives Webdesign ist keine einzelne Technik, sondern eine Haltung. Es zwingt uns, Inhalte und Funktionen konsequent aus der Perspektive der Nutzer zu denken und technische Grenzen als Gestaltungsspielräume zu begreifen. Diese Haltung hat sich als Leitfaden durch alle Kapitel gezogen – von der Theorie über die strategische Planung bis zur praktischen Umsetzung. Sie wird uns auch in Zukunft begleiten, weil Endgeräte, Netzwerke und Erwartungen sich weiter verändern werden. Wer sich darauf einlässt, legt das Fundament für digitale Angebote, die morgen genauso funktionieren wie heute.

Abbildungsverzeichnis

2.1	Funktionsweise von Single Sign-On (Quelle: [ARB:Web05])	14
2.2	Rollenverteilung im OAuth 2.0 Standard (Quelle: [ARB:Web05]) . .	15
2.3	OAuth2 Authorization Code Flow (Quelle: [ARB:Web06])	17
3.1	Service Provider anlegen – Name und Unique ID (Quelle: [ARB:Web17])	25
3.2	Technische Metadaten – OIDC Konfiguration (Quelle: <i>id-austria.gv.at</i> , [ARB:Web17])	26
3.3	Technische Metadaten – SAML Konfiguration (Quelle: <i>id-austria.gv.at</i> , [ARB:Web17])	27
3.4	OIDC Secret verwalten (Quelle: <i>id-austria.gv.at</i> , [ARB:Web17]) . .	28
3.5	Auswahlmöglichkeit der Authentifizierung beim ID Austria Login (Quelle: [ARB:Web09])	29
4.1	Registrierung mit ID Austria	36
4.2	Ausweis – Hochformat	37
4.3	Ausweis – Querformat Vorderseite	37
4.4	Ausweis – Querformat Rückseite	38
4.5	Ausweis – Gesperrt	38
4.6	Anmeldung mit ID Austria	39
4.7	Kalenderansicht Mitglieder	40

4.8	Kalendereintrag erstellen	40
4.9	Zahlungsseite	41
5.1	Systemarchitektur der Vereins-App	46
5.2	User Tabelle	47
5.3	Admin Tabelle	47
5.4	Region Tabelle	47
5.5	Locality Tabelle	47
5.6	Payment Tabelle	48
5.7	Calendar Event Tabelle	48
5.8	Push Notification Tabelle	48
5.9	Data Access Event Tabelle	49
5.10	Admin Tabelle	49
5.11	Region Tabelle	49

Tabellenverzeichnis

Listings

2.1	Beispiel Authorization Request (Quelle: <i>[ARB:Web06]</i>)	17
2.2	Beispiel Authorization Response (Quelle: <i>[ARB:Web06]</i>)	18
2.3	Beispiel Token Request (Quelle: <i>[ARB:Web06]</i>)	18
2.4	Beispiel Token Response (Quelle: <i>[ARB:Web06]</i>)	18
3.1	Beispiel OIDC Authorization Request (Quelle: <i>id-austria.gv.at, [ARB:Web09]</i>)	28
3.2	Beispiel Authentication Response (Quelle: <i>[ARB:Web09]</i>)	30
3.3	Beispiel OIDC Token Request (Quelle: <i>[ARB:Web09]</i>)	30
3.4	Beispiel OIDC Successful Token Response (Quelle: <i>[ARB:Web09]</i>)	30
3.5	Dekodiertes Beispiel eines OIDC ID Token Payloads (Quelle: <i>[ARB:Web09]</i>)	31
5.1	Mitgliedschaftsprüfung im JWT Service	50
5.2	Admin-Flag Prüfung im JWT Service	51
5.3	JWT Claim Erstellung	51
5.4	JWT Secret Konfiguration	52
5.5	Security Filter Chain Konfiguration	52
5.6	JWT Header im Flutter Client	53
5.7	Admin-Flags aus der Datenbank in den JWT schreiben	53
5.8	Ausweis Controller Endpoint	54
5.9	Ausweis Service – Mitgliedschaft validieren	54

Literaturverzeichnis

[PN:Web01] <https://ambient.digital/wissen/blog/qualitaet-softwareentwicklung/>
Was ist Qualitätssicherung
Zugriff 06.09.2025

[PN:Web02] <https://www.codecentric.de/wissens-hub/blog/goldene-wasserhaehne-wie-wichtig-ist-qualitaet-in-der-softwareentwicklung>
Wie wichtig ist Softwarequalität
Zugriff am 06.09.2025

[PN:Web03] <https://www.johner-institut.de/blog/iec-62304-medizinische-software/iso-9126-und-iso-25010/>
ISO/IEC 25010: Qualitätsmodelle für Softwareprodukte
Zugriff am 07.09.2025

[PN:Web04] <https://www.concept-pro.de/blog/qm-vs-qs-welcher-unterschied-besteht-zwischen-qualitaetsmanagement-und-qualitaetssicherung/>
QM vs. QS – welcher Unterschied besteht
Zugriff am 07.09.2025

[PN:Web05] <https://blog.dgq.de/qualitaetsmanagement-oder-qualitaetssicherung/>
Qualitätsmanagement oder Qualitätssicherung?
Zugriff am 07.09.2025

[PN:Web06] <https://sentin.ai/unterschiede-qm-qs/>
Unterschiede QM und QS
Zugriff am 08.09.2025

[PN:Web07] <https://www.babtec.de/blog/unterschied-qualitaetsmanagement-qualitaetssicherung>
QM und QS – nur gemeinsam erfolgreich
Zugriff am 08.09.2025

[PN:Web08] <https://moldstud.com/articles/p-importance-of-quality-assurance-in-software-development>

Quality assurance

Zugriff am 08.09.2025

[PN:Web09] <https://www.gecko.de/wissenshub/qualitaetssicherung-in-der-software-entwicklung-so-stellen-sie-die-qualitaet-ihrer-software-sicher/>

Wie stellt man Qualität sicher

Zugriff am 08.09.2025

[PN:Web10] <https://www.attek.eu/news/software-quality-vs-time-to-market>

Time-to-market

Zugriff am 27.10.2025

[PN:Web11] <https://www.onlinesicherheit.gv.at/Themen/Experteninformation/Secure-Lifecycle/Softwarequalitaet-als-Fundament-der-sicheren-Softwareentwicklung.html>

Softwareentwicklung.html

Softwarequalität in der Softwareentwicklung

Zugriff am 27.10.2025

[PN:Web12] <https://www.iso25000.com/index.php/en/22-english/iso-iec-25010>

Iso25010

Zugriff am 28.10.2025

[PN:Web13] <https://www.geeksforgeeks.org/software-engineering/difference-between-static-and-dynamic-testing/>

Static vs. dynamic testing

Zugriff am 28.10.2025

[PN:Web14] <https://www.scirp.org/html/35253.html>

Iso25010

Zugriff am 28.10.2025

[PN:Web15] <https://cacm.acm.org/blogcacm/the-importance-of-robust-documentation-in-software-development>

Dokumentation in der Softwareentwicklung

Zugriff am 29.10.2025

[PN:Web16] <https://www.peterjohann-consulting.de/qualitativ-oder-quantitativ/>

Quantitativ oder Qualitativ

Zugriff am 29.10.2025

[PN:Web17] https://vmsoftwarehouse.de/15-masnahmen-zur-qualitatssicherung-in-der-softwareentwicklungWelche_Rolle_spielt_die_Qualitaetssicherung_in_der_Softwareentwicklung

Quantitativ oder Qualitativ

Zugriff am 29.10.2025

- [PN:Web18] <https://qawerk.de/blog/qa-der-softwareentwicklung-rolle-und-bedeutung/>
Quantitativ oder Qualitativ
Zugriff am 29.10.2025
- [PN:Web19] <https://wi-lex.de/index.php/lexikon/entwicklung-und-management-von-informationssystemen/systementwicklung/management-der-systementwicklung/software-qualitaetsmanagement/qualitaetsmerkmale-von-software/>
8 dimensionen von ISO 25010
Zugriff am 29.12.2025
- [PN:Web20] <https://www.sps-profis.de/definition/iso-25010>
Iso25010 Definition
Zugriff am 29.12.2025
- [PN:Web21] <https://visuresolutions.com/alm-guide/quality-assurance>
Quality assurance und SDLC
Zugriff am 18.12.2025
- [PN:Web22] <https://www.miyagami.com/insights/the-importance-of-qa-in-development-lifecycle>
Development Lifecycle
Zugriff am 18.12.2025
- [PN:Web23] <https://www.capicua.com/blog/importance-of-quality-assurance-in-software-development>
Wichtigkeit der Qualitätssicherung in der Softwareentwicklung
Zugriff am 19.12.2025
- [PN:Web24] <https://medium.com/%40testwithblake/why-qa-should-be-involved-early-in-the-software-development-lifecycle-9edd98d943fa>
Wieso Qualitätssicherung früh eingebaut werden sollte
Zugriff am 19.12.2025
- [PN:Web25] <https://www.eliteitteam.com/blogs/qa-in-sdlc>
Qualitätssicherung in der sdlc
Zugriff am 19.12.2025
- [PN:Web26] <https://www.handbuch-experten.de/blog/qualitaetssicherung-technische-dokumentation/>
Qualitätssicherung durch technische Dokumentation
Zugriff am 28.12.2025
- [PN:Web27] <https://www.vorest-ag.com/Qualitaetssicherung-Methoden>
Qualitätssicherung – Methoden und Maßnahmen
Zugriff am 28.12.2025

- [PN:Web28] <https://www.objectbay.com/blog/was-ist-code-review-inklusive-checkliste>
Was ist Code Review? Inklusive Checkliste
Zugriff am 02.01.2026
- [PN:Web29] <https://www.ionos.at/digitalguide/websites/web-entwicklung/code-review/>
Code Review – Definition und Vorteile
Zugriff am 02.01.2026
- [PN:Web30] <https://www.it-agile.de/agiles-wissen/agile-entwicklung/was-ist-pair-programming/>
Was ist Pair Programming?
Zugriff am 02.01.2026
- [PN:Web31] <https://www.studysmarter.de/studium/informatik-studium/anwendungen-informatik/versionskontrolle/>
Versionskontrolle
Zugriff am 03.01.2026
- [PN:Web32] <https://www.norb.it/branching-strategien-in-der-softwareentwicklung-ein-umfassender-ueberblick/>
Branching-Strategien in der Softwareentwicklung
Zugriff am 03.01.2026
- [PN:Web33] <https://about.gitlab.com/de-de/topics/ci-cd/>
Was ist CI/CD?
Zugriff am 09.01.2026
- [PN:Web34] <https://www.redhat.com/de/topics/devops/what-is-ci-cd>
Was ist CI/CD?
Zugriff am 09.01.2026
- [PN:Web35] <https://www.cortex.io/post/measuring-and-improving-code-quality>
Measuring and Improving Code Quality
Zugriff am 10.01.2026
- [PN:Web36] <https://www.geeksforgeeks.org/software-engineering/code-coverage-testing-in-software-testing/>
Code Coverage - Formel
Zugriff am 10.01.2026
- [PN:Web37] <https://www.atlassian.com/de/continuous-delivery/software-testing/code-coverage>
Code Coverage
Zugriff am 10.01.2026

- [PN:Web38] <https://serhat-ozdursun.medium.com/why-bug-rate-should-be-a-kpi-for-developers-not-just-qa-1fcd349add25>
Bug Rate - Formel
Zugriff am 11.01.2026
- [PN:Web39] <https://www.metridev.com/metrics/bug-rate-a-complete-guide>
Bug Rate – A Complete Guide
Zugriff am 11.01.2026
- [PN:Web40] <https://dcm.dev/docs/metrics/function/maintainability-index/>
Maintainability Index
Zugriff am 11.01.2026
- [PN:Web41] <https://learn.microsoft.com/en-us/visualstudio/code-quality/code-metrics-maintainability-index-range-and-meaning?view=visualstudiox>
Maintainability Index Explained
Zugriff am 17.01.2026
- [PN:Web42] <https://www.ranorex.com/blog/defect-leakage/>
Defect leakage - formel
Zugriff am 17.01.2026
- [PN:Web43] https://qse.ifs.tuwien.ac.at/wp-content/uploads/03P_QM_wid_20040204.pdf
Verbesserungen
Zugriff am 05.02.2026
- [PN:Web44] <https://www.ibm.com/de-de/think/topics/root-cause-analysis>
Root cause analysis
Zugriff am 05.02.2026
- [PN:Web45] <https://www.vorest-ag.com/Qualitaetssicherung-Methoden/Wissen/Ishikawa-Diagramm>
Ishikawa-Diagramm
Ishikama-Diagramm
Zugriff am 05.02.2026
- [PN:Web46] <https://teachingagile.com/de/sdlc/modelle/v-model>
V-model
Zugriff am 07.02.2026
- [PN:Web47] <https://dh-cologne.github.io/java-wegweiser/articles/JUnit.html>
V-unit tests
Zugriff am 07.02.2026
- [PN:Web48] <https://walter-test-engineering.de/lexikon/testpyramide/>
Testpyramide
Zugriff am 17.02.2026

- [PN:Web49] <https://www.testautomatisierung.org/lexikon/integrationstests/>
Integrationstest
Zugriff am 17.02.2026
- [PN:Web50] <https://www.ibm.com/de-de/think/topics/system-testing>
Integrationstest
Zugriff am 17.02.2026
- [PN:Web51] <https://pw-akademie.eu/glossar/abnahmetest/>
Abnahmetests
Zugriff am 05.03.2026
- [PN:Web52] <https://pcg.io/de/insights/qa-strategien-fuer-automatisierte-und-manuelle-tests/>
Manuelles vs. automatisiertes Testen
Zugriff am 05.03.2026
- [ARB:Web01] <https://www.ibm.com/de-de/think/topics/digital-identity>
Was ist digitale Identität? – IBM
08.03.2026
- [ARB:Web02] <https://www.ibm.com/de-de/think/topics/identity-access-management>
Identity and Access Management (IAM) – IBM
08.03.2026
- [ARB:Web03] <https://aws.amazon.com/de/what-is/sso/>
Was ist Single Sign-On? – Amazon Web Services
08.03.2026
- [ARB:Web04] <https://auth0.com/de/intro-to-iam/what-is-oauth-2>
What is OAuth 2.0? – auth0
08.03.2026
- [ARB:Web05] <https://blog.doubleslash.de/software-technologien/die-rollverteilung-im-oauth-2-0-standard>
Die Rollenverteilung im OAuth 2.0 Standard – doubleslash
08.03.2026
- [ARB:Web06] <https://blog.doubleslash.de/software-technologien/oauth-2-0-der-authorization-code-flow-im-detail/>
OAuth 2.0 – Der Authorization Code Flow im Detail – doubleslash
11.03.2026
- [ARB:Web07] <https://b-nova.com/home/content/why-oidc-is-not-the-same-as-oauth-and-why-you-should-never-do-without-it/>
Why OIDC is not the same as OAuth – b-nova
11.03.2026

- [ARB:Web08] <https://www.id-austria.gv.at/de/hilfe/hilfe-zu-ida/generelle-info>
Generelle Informationen zu ID Austria – ID Austria
12.03.2026
- [ARB:Web09] <https://www.id-austria.gv.at/de/developer/anbinden/anbindung-mit-openid-connect>
Anbindung mit OpenID Connect – ID Austria
12.03.2026
- [ARB:Web10] <https://www.ionos.de/digitalguide/websites/web-entwicklung/json-web-token-jwt-vorgestellt/>
JSON Web Token (JWT) vorgestellt – IONOS
12.03.2025
- [ARB:Web11] <https://ausbildung-in-der-it.de/lexikon/pkce>
PKCE – Lexikon – Ausbildung in der IT
12.03.2025
- [ARB:Web12] <https://www.id-austria.gv.at/de/hilfe/hilfe-zu-ida/authentifizierungsfaktoren>
Authentifizierungsfaktoren – ID Austria
14.03.2026
- [ARB:Web13] <https://focus.namirial.com/de/vertrauensniveaus-level-of-assurance/>
Vertrauensniveaus – Level of Assurance – Namirial
14.03.2025
- [ARB:Web14] <https://www.id-austria.gv.at/de/unternehmen-service-provider/service-provider-werden/anbindung>
Anbindung – SAML2 und OIDC Vergleich – ID Austria
15.03.2026
- [ARB:Web15] <https://www.id-austria.gv.at/de/developer/registrieren>
Registrierung als Service Provider – ID Austria
15.03.2026
- [ARB:Web16] <https://www.id-austria.gv.at/de/developer/registrieren/private-sps>
Registrierung privater Service Provider – ID Austria
15.03.2026
- [ARB:Web17] [https://www.id-austria.gv.at/de/developer/registrieren/service-provider-registrierung-\(ida-spr\)/Anlage-und-Verwaltung-von-Anwendungen](https://www.id-austria.gv.at/de/developer/registrieren/service-provider-registrierung-(ida-spr)/Anlage-und-Verwaltung-von-Anwendungen)
Anlage und Verwaltung von Anwendungen – ID Austria
16.03.2026

- [ARB:Web18] Polizeisportverein Austria (2025).
MockUps_PSPA – Internes Dokument.
- [ARB:Web19] <https://dsgvo-gesetz.de/art-5-dsgvo/>
Art. 5 DSGVO – Grundsätze für die Verarbeitung personenbezogener Daten
19.03.2025
- [ARB:Web20] <https://de.wikipedia.org/wiki/HMAC>
HMAC – Hash-based Message Authentication Code – Wikipedia
20.03.2025
- [ARB:Web21] <https://medium.com/@gunawardena.buddika/jwts-csrf-tokens-465e5d4f91cf>
JWTs & CSRF Tokens – Medium
20.03.2025
- [UE:Book01] *Blockchain 2.0*
Dr. Julian Hosp
ISBN 978-3-95972-159-2
- [UE:Web01] <https://der-it-blog.de/2024/geschichte-der-zahlungssysteme-im-internet>
Geschichte der Zahlungssysteme im Internet
29.09.2025
- [UE:Web02] <https://www.nexi.at/de/ratgeber/ratgeber-uebersicht/online-bezahl-systeme>
Online Bezahlssysteme
30.09.2025
- [UE:Web03] <https://www.krypto-magazin.de/glossar/zahlungssystem>
Zahlungssystem
30.09.2025
- [UE:Web04] <https://www.oenb.at/finanzmarkt/zahlungssystemaufsicht.html>
Zahlungssystemaufsicht
30.09.2025
- [UE:Web05] <https://www.pwc.de/de/finanzdienstleistungen/payment-fraud-studie.html?>
Sicherheit und Betrugsprävention
01.10.2025
- [Ue.Web06] <https://irf.fhnw.ch/server/api/core/bitstreams/3173fb88-b1d7-4006-9fdf-ca3495da6f7b/content>
Anforderungen an Zahlungssystemn
02.10.2025

[UE:Web07] https://ec.europa.eu/commission/presscorner/detail/it/qanda_23_544
Payment Services
02.10.2025

[UE:08]

[UE:Web08] https://www.handelsverband.at/fileadmin/content/Presse_Publikationen/-PSD2_Ueberblick_fuer_Haendler.pdf
PSD2
8.12.2025

[UE:Web09] <https://www.pwc.at/de/newsletter/forensic-services-update/das-eu-aml-paket-.html>
Anti Money Laundry
8.12.2025

[UE:Web10] <https://www.twobirds.com/de/insights/2024/global/eu-aml-package—a-new-adventure-begins>
EU AML Package - ein neues Abenteuer beginnt
9.12.2025

[UE:Web11] <https://exxeta.com/blog/eu-aml-paket-alma-regeln-finanzkriminalitaet>
EU-AML-Paket AMLA – Endlich der große Wurf gegen Finanzkriminalität?
9.12.2025

[UE:Web12] <https://www.onlinesicherheit.gv.at/Themen/Experteninformation/Normen-und-Standards/PCI-DSS.html>
Payment Card Industry Data Security Standard (PCI DSS)
17.12.2025

[UE:Web13] <https://www.ombudsstelle.at/bezahlen-im-internet/wie-funktioniert-eine-kreditkartenzahlung/>
Wie funktioniert eine Kreditkartenzahlung?
17.12.2025

[UE:Web14] <https://www.hettwer-beratung.de/sepa-spezialwissen/sepa-lastschrift-sdd/sepa-lastschriftverfahren-grundlagen/>
SEPA Lastschriftverfahren - SEPA Grundlagen
20.12.2025

[UE:Web15] <https://www.financefluss.de/banking/lastschriftverfahren/>
SEPA-Lastschrift: Wie kann man bequem per Lastschrift bezahlen?
20.12.2025

[UE:Web15] <https://www.oenb.at/Zahlungsverkehr/bargeldloses-bezahlen/SEPA-Zahlungsinstrumente/SEPA-Lastschriftverfahren.html>

SEPA-Lastschriftverfahren
20.12.2025

[UE:Web16] <https://qonto.com/de/blog/bezahlmethoden/ueberweisung/sofortueberweisung>
Was ist eine Sofortüberweisung – und wie funktioniert sie?
20.12.2025

[UE:Web17] <https://bankinggeek.com/sofortueberweisung/>
Sofortüberweisung: Sicherheit, Kosten und Alternativen
20.12.2025

[UE:Web18] <https://www.sumup.com/de-de/wachsen/zahlungen/sofortueberweisung-und-echtzeitueberweisung/>
Sofortüberweisung und Echtzeitüberweisung
20.12.2025

[UE:Web19] <https://www.mollie.com/at/growth/3d-secure-3ds2-guide>
3D Secure-Authentifizierung und 3D Secure 2 erklärt
21.12.2025

[UE:Web20] <https://www.shopify.com/de/blog/lokale-zahlungsarten>
Vergleich Zahlungsarten
21.12.2025

[UE:Web21] <https://www.onlinesicherheit.gv.at/Services/News/Wallet-Apps-sicher-nutzen.html>
Die digitale Wallet nutzen: Allgemeiner Überblick, Anbieter und Sicherheit
21.12.2025

[UE:Web22] <https://www.computerweekly.com/de/definition/Tokenization>
Tokenization (Tokenisierung)
21.12.2025

[UE:Web23] <https://www.netzwelt.de/nfc/>
NFC
21.12.2025

[UE:Web24] <https://gi.de/informatiklexikon/near-field-communication-nfc>
Near Field Communication (NFC)
21.12.2025

[UE:web25] <https://utimaco.com/de/service/wissensbasis/hardware-sicherheitsmodule/was-ist-host-card-emulation-hce>
Was ist Host Card Emulation (HCE)?
02.01.2026

- [UE:Web26] <https://developer.android.com/develop/connectivity/nfc/hce?hl=dejava>
Hostbasierte Kartenemulation – Übersicht
02.01.2026
- [UE:Web27] <https://developer.apple.com/support/hce-transactions-in-apps/>
HCE-Apple
02.01.2026
- [UE:Web28] <https://www.bundesbank.de/resource/blob/903522/ad812053f4c0baacacf-cd8eb49549537/472B63F073F071307366337C94F8C870/2023-01-mobile-payments-data.pdf>
Die Nutzung von Mobile Payments
02.01.2026
- [UE:Web29] <https://n26.com/de-de/wallet>
Die besten digitalen Wallets
02.01.2026
- [UE:Web30] <https://www.alibaba.com/product-insights/apple-pay-google-pay-samsung-pay-has-market-share-actually-changed-in-2025.html>
Apple Pay Google Pay Samsung Pay Has Market Share Actually Changed In 2025
03.01.2026
- [UE:Web30] <https://www.apple.com/at/newsroom/2014/09/09Apple-Announces-Apple-Pay/>
Apple Pay (Apple)
03.01.2026
- [UE:Web31] <https://electroiQ.com/stats/apple-pay-vs-google-pay-statistics/>
Apple/Google Pay Nutzerzahlen und Merkmale
03.01.2026
- [UE:Web32] <https://www.googlewatchblog.de/2018/05/vor-deutschland-start-google/>
Google Pay Geschichte
03.01.2026
- [UE:Web34] <https://www.business.com/articles/google-pay-vs-apple-pay-vs-samsung-pay/>
Samsung Pay
03.01.2026
- [UE:Web35] <https://electroiQ.com/stats/samsung-pay-statistics/>
Samsung Pay Statistik
03.01.2026

- [UE:Web36] <https://www.enisa.europa.eu/sites/default/files/publications/WP2016%203-1%204%20Mobile%20Payments%20Security.pdf> m
ENISA: Security of Mobile Payments and Digital Wallets
11.01.2026
- [UE:Web37] <https://bitcoin-kurier.de/dezentralisierung-von-kryptowaehrungen-und-blockchain-technologie/>
Dezentralisierung
05.02.2026
- [UE:Web38] <https://www.bitpanda.com/de/academy/was-sind-smart-contracts-und-wie-funktionieren-sie>
Smart Contract - Bitpanda
12.02.2026
- [UE:Web39] <https://bitcoin-2go.de/smart-contracts/>
Smart Contract - Bitcoin2go
12.02.2026
- [UE:Web40] <https://zeeg.me/de/blog/content/was-ist-stripe>
Was ist Stripe
23.2.2026
- [UE;Web41] <https://docs.stripe.com/?locale=de-DE>
Stripe Dokumentation
01.03.2026
- [UE:Web42] <https://www.sparkasse.de/pk/ratgeber/finanzplanung/banking-tipps/moderne-bezahlsysteme.html>
Sparkasse: Die Zukunft des Bezahlens
15.03.2026
- [UE:Web43] <https://bankinghub.de/research-markets/zahlungsverkehr-zukunft>
Zahlungsverkehr der Zukunft – aktuelle Trends
15.03.2026
- [UE:Web44] <https://www.bitpanda.com/de/academy/was-ist-eine-wallet-und-wo-bekomme-ich-eine>
Bitpanda Walletserklärung
15.03.2026
- [UE:Web45] <https://docs.stripe.com/stripe-apps/how-stripe-apps-work?locale=de-DE>
Funktionsweise von Stripe-Apps
24.03.2026

- [UE:Web46] <https://docs.stripe.com/testing>
Stripe-Testing Dokumentation
24.03.2026
- [UE:Web47] <https://www.baeldung.com/spring-postconstruct-predestroy>
Spring PostConstruct Annotation
24.03.2026
- [UE:Web48] <https://docs.stripe.com/currencies>
Stripe-Beträge
24.03.2026
- [UE:Web49] <https://spring.io/guides/gs/rest-service-cors>
Spring-CORS
24.03.2026
- [UE:Web50] <https://aithor.com/essay-examples/elektronische-zahlungssysteme-fur-den-e-commerce>
DSGVO E-Commerce
24.03.2026
- [UE:Web51] <https://relai.app/de/blog/bitcoin-transfer-dauer/>
Bitcoin Transfer
24.03.2026
- [UE:Web52] <https://support.bitpanda.com/hc/de/articles/360000902745-Wie-kann-ich-Kryptowährungen-kaufen>
Bitcoin kaufen
24.03.2026
- [UE:Web53] <https://checkout.nexi.de/hubfs/ECom-Report/2024/E-Commerce%20Report%202024%20-%20Österreich%20-%20Nexi%20Group.pdf>
E-Commerce Report 2024 Österreich
24.03.2026
- [SD:Web01] <https://www.ris.bka.gv.at/GeltendeFassung.wxe?Abfrage=Bundesnormen-Gesetzesnummer=20004228>
Bundes-Behindertengleichstellungsgesetz
04.10.2025
- [SD:Web02] https://www.oesterreich.gv.at/de/themen/menschen_mit_behinderungen/-gleichstellung-von-menschen-mit-behinderungen/Seite.1871000
Allgemeines zur Gleichstellung von Menschen mit Behinderungen
04.10.2025

- [SD:Web03] <https://www.sozialministerium.gv.at/Themen/Soziales/Menschen-mit-Behinderungen/Behindertengleichstellung.html>
Sozialministerium Behindertengleichstellung
04.10.2025
- [SD:Web04] <https://www.sozialministerium.gv.at/Themen/Soziales/Menschen-mit-Behinderungen/UN-Behindertenrechtskonvention.html>
Sozialministerium UN-Behindertenrechtskonvention
04.10.2025
- [SD:Web05] Link:<https://www.aerzteblatt.de/archiv/behinderungen-erweiterte-definition-der-who-23b32907-e12f-48c5-89d1-9e73977ff9e9>
Deutsches Ärzteblatt WHO
04.10.2025
- [SD:Web06] Link:<https://www.aerzteblatt.de/archiv/behinderungen-erweiterte-definition-der-who-23b32907-e12f-48c5-89d1-9e73977ff9e9>
WKO Definitionen
20.12.2025
- [SD:Web07] Link:<https://www.w3.org/TR/WCAG21/>
WCAG21
20.12.2025
- [SD:Web08] <https://www.lebensgross.at/news/digitale-welt/>
Menschen mit Behinderung und alte Menschen mit der digitalen Welt
20.12.2025
- [SD:Web09] <https://www.ffg.at/en/news/ffg-publishes-first-austrian-monitoring-report-digital-accessibility>
Monitoring Report
20.12.2025
- [SD:Web10] https://commission.europa.eu/strategy-and-policy/policies/justice-and-fundamental-rights/disability/union-equality-strategy-rights-persons-disabilities-2021-2030/european-accessibility-act_en
EU Accessibility Act
21.12.2025
- [SD:Web11] <https://digital-strategy.ec.europa.eu/en/policies/web-accessibility-directive-standards-and-harmonisation>
Web Accessibility Directive
21.12.2025

[SD:Web12] <https://digital-strategy.ec.europa.eu/en/policies/web-accessibility>
WAD
21.12.2025

[SD:Web13]

[SD:Web14] <https://www.ris.bka.gv.at/GeltendeFassung.wxeAbfrage=Bundesnormen-Gesetzesnummer=20004228>
Zitat BGStG Definition Barrierefreiheit
21.12.2025

[SD:Web15] <https://www.ris.bka.gv.at/GeltendeFassung.wxe?Abfrage=Bundesnormen-Gesetzesnummer=20004228§6>
Österreichisches Bundes- Behindertengleichstellungsgesetz (BGStG)
21.12.2025

[SD:Web16] <https://www.ris.bka.gv.at/GeltendeFassung.wxe?Abfrage=Bundesnormen-Gesetzesnummer=20012316FassungVom=2025-06-28>
Barrierefreiheitsgesetz "Österreich (Barrierefreiheitsgesetz 2025)
21.12.2025

[SD:Web17] <https://www.ris.bka.gv.at/GeltendeFassung.wxe?Abfrage=Bundesnormen-Gesetzesnummer=20010727>
Web-Zug "anglichkeits-Gesetz
21.12.2025

[SD:Web18] <https://www.wcag.com/compliance/en-301-549/>
CAG 2.1 vs EN 301 549
21.12.2025

[SD:Web19] <https://digital-strategy.ec.europa.eu/en/policies/web-accessibility>
WAD)
21.12.2025

[SD:Web20] <https://webaim.org/projects/million/>
WebAIM Million)
11.01.2026

[SD:Web21] <https://www.microsoft.com/insidetrack/blog/shifting-left-to-get-accessibility-right-at-microsoft>
Microsoft shifting left)
11.01.2026

[SD:Web22] <https://www.acquia.com/blog/accessibility-statistics>
Acquia Profitabilität Accessibility)
11.01.2026

- [SD:Web23] <https://www.forrester.com/blogs/the-billion-customer-digital-accessibility-opportunity/>
Forrester)
11.01.2026
- [SD:Web24] <https://inclusive.microsoft.design/>
Microsoft Accessibility Design)
11.01.2026
- [SD:Web25] <https://www.w3.org/WAI/test-evaluate/tools/list/>
W3 Tool List)
11.01.2026
- [SD:Web26] <https://aqua-cloud.io/accessibility-testing-tools/>
Aqua Tools)
11.01.2026
- [SD:Web27] <https://g3ict.org/publication/benefits-and-costs-of-e-accessibility-business-case-white-paper>
g3ict Whitepaper Benefits and Costs of e-Accessibility)
11.01.2026
- [SD:Web28] <https://www.w3.org/WAI/test-evaluate/involving-users/>
W3 involving Users in Tests)
11.01.2026
- [SD:Web29] https://de.wikipedia.org/wiki/World_Wide_Web_Consortium
Wikipedia W3C)
11.01.2026
- [SD:Web30] <https://www.w3.org/TR/WCAG21/>
Web Content Accessibility Guidelines)
11.01.2026
- [SD:Web31] <https://www.w3.org/WAI/WCAG2AAA-Conformance>
WCAG Level)
11.01.2026
- [SD:Web32] <https://www.w3.org/TR/WCAG22>
WCAG 2.2 Regelungen)
11.01.2026
- [SD:Web32] <https://www.w3.org/TR/WCAG22>
WCAG 2.2 Regelungen)
11.01.2026

- [SD:Web33] <https://www.w3.org/WAI/standards-guidelines/wcag/conformance-logos/>
W3C WCAG Logo einbauen)
11.01.2026
- [SD:Web34] https://de.wikipedia.org/wiki/Web_Content_Accessibility_Guidelines
Wikipedia WCAG)
11.01.2026
- [SD:Web35] <https://www.w3.org/TR/wcag-em-2/>
W3C Accessibility Guidelines Evaluation Methodology)
11.01.2026
- [SD:Web36] <https://developer.mozilla.org/de/docs/Web/Accessibility/ARIA>
Mozilla Aria)
11.01.2026
- [SD:Web37] <https://medium.com/code-and-coffee/pac-2024-chronicles-the-accessibility-saga-of-pdfs-a09ff4b6290b>
PDF Accessibility)
11.01.2026
- [SD:Web37] <https://netz-barrierefrei.de/en/screenreader-in-use.html>mozToCId841645
Screenreader Overview)
24.03.2026
- [SD:Web38] <https://netz-barrierefrei.de/en/screenreader-in-use.html>mozToCId841645
Screenreader Overview)
24.03.2026
- [SD:Web39] <https://data.europa.eu/apps/data-visualisation-guide/braille-displays>
Braille-Displays)
24.03.2026
- [SD:Web40] <https://accessibility.wfu.edu/resources/assistive-technology/speech-to-text/>
Speech to text input)
24.03.2026
- [SD:Web41] <https://mediax.stanford.edu/research-projects/mffd-winograd/>
Eye Tracker)
24.03.2026
- [SD:Web42] <https://www.w3.org/WAI/test-evaluate/tools>
Testing Tools)
24.03.2026

- [CL:Web1] Marcotte, Ethan:
Responsive Web Design
A List Apart, 25. Mai 2010
<https://alistapart.com/article/responsive-web-design/>
Letzer Zugriff am 24.03.2026
- [CL:Web2] Clemson University:
Responsive Design Guide
Clemson University
<https://www.clemson.edu/accessibility/digital/guides/web/responsive-design.html>
Letzer Zugriff am 24.03.2026
- [CL:Web3] TeamTreehouse Blog:
Rapidly Prototype Websites
TeamTreehouse, 2013
<https://blog.teamtreehouse.com/rapidly-prototype-websites>
Letzer Zugriff am 24.03.2026
- [CL:Web4] Google Developers:
Responsive Web Design Basics
Google Developers
<https://developers.google.com/web/fundamentals/design-and-ux/responsive>
Letzer Zugriff am 24.03.2026
- [CL:Web5] Nielsen Norman Group:
Responsive Web Design: Definition and Best Practices
Nielsen Norman Group
<https://www.nngroup.com/articles/responsive-web-design-definition/>
Letzer Zugriff am 24.03.2026
- [CL:Web6] Kulturbanause Blog:
Mobile First und Progressive Enhancement
Kulturbanause Blog
<https://kulturbanause.de/blog/mobile-first-progressive-enhancement/>
Letzer Zugriff am 24.03.2026
- [CL:Web7] McGrane, Karen:
Responsive Design Won't Fix Your Content Problem
A List Apart
<https://alistapart.com/column/responsive-design-wont-fix-your-content-problem/>
Letzer Zugriff am 24.03.2026
- [CL:Web8] Helio:
Graceful Degradation Definition

Helio
<https://helio.app/definitions/graceful-degradation/>
Letzer Zugriff am 24.03.2026

[CL:Page1] Wroblewski, Luke:
Mobile First (Whitepaper)
PDF Dokument
Letzer Zugriff am 24.03.2026

[CL:Web9] Salminen, Ariel:
Responsive Workflow
Ariel Salminen, 2012
<https://arielsalminen.com/2012/responsive-workflow/>
Letzer Zugriff am 24.03.2026

[CL:Web10] Boulton, Mark:
Responsive Summit Workflow
Mark Boulton
<https://markboulton.co.uk/journal/responsive-summit-workflow/>
Letzer Zugriff am 24.03.2026

[CL:Web11] CSS-Tricks:
How to Develop and Test a Mobile-First Design in 2021
CSS-Tricks, 2021
<https://css-tricks.com/how-to-develop-and-test-a-mobile-first-design-in-2021/>
Letzer Zugriff am 24.03.2026

[CL:Web12] International Organization for Standardization (ISO):
ISO 9241-11:2018 Ergonomics of human-system interaction Part 11: Usability: Definitions and concepts
ISO
<https://www.iso.org/standard/63500.html>
Letzer Zugriff am 24.03.2026

[CL:Web13] WEKA CE-Kennzeichnung:
Die Grundsätze der Dialoggestaltung nach ISO 9241-110
WEKA
<https://www.weka-manager-ce.de/betriebsanleitung/grundsaeetze-dialoggestaltung-iso-9241-110/>
Letzer Zugriff am 24.03.2026

[CL:Web14] International Organization for Standardization (ISO):
ISO 9241-112:2017 Ergonomics of human-system interaction Part 112: Principles for the presentation of information
ISO

<https://www.iso.org/standard/64840.html>
Letzer Zugriff am 24.03.2026

[CL:Page2] Magic Number Seven
Magic Number Seven
<https://labs.la.utexas.edu/gilden/files/2016/04/MagicNumberSeven-Miller1956.pdf>
Letzer Zugriff am 24.03.2026

[CL:Web41] Hicks Law
Hicks Law
<https://vwo.com/blog/what-is-hicks-law-and-how-it-can-simplify-choices/>
Letzer Zugriff am 24.03.2026

[CL:Web15] Leserlich:
leserlich.info
Leserlich
<https://leserlich.info/zeichen/schriftgroesse>
Letzer Zugriff am 24.03.2026

[CL:Web16] Nielsen Norman Group:
10 Usability Heuristics for User Interface Design
Nielsen Norman Group
<https://www.nngroup.com/articles/ten-usability-heuristics/>
Letzer Zugriff am 24.03.2026

[CL:Web17] Apple Developer:
Human Interface Guidelines
Apple Developer
<https://developer.apple.com/design/human-interface-guidelines>
Letzer Zugriff am 24.03.2026

[CL:Web18] Google:
Material Design 3
Google
<https://m3.material.io/>
Letzer Zugriff am 24.03.2026

[CL:Web19] Codecademy:
Hick's Law (UX Psychology)
Codecademy
<https://www.codecademy.com/resources/docs/uiux/ux-psychology/hicks-law>
Letzer Zugriff am 24.03.2026

[CL:Web20] GeeksforGeeks:
Principles of Usability

GeeksforGeeks

<https://www.geeksforgeeks.org/system-design/principles-of-usability/>

Letzer Zugriff am 24.03.2026

[CL:Web21] GeeksforGeeks:

How to Maximize Readability with Good Web Typography

GeeksforGeeks

<https://www.geeksforgeeks.org/websites-apps/how-to-maximize-readability-with-good-web-typography/>

Letzer Zugriff am 24.03.2026

[CL:Web22] MDN Web Docs:

Responsive web design

MDN Web Docs

https://developer.mozilla.org/en-US/docs/Learn_web_development/Core/CSS_layout/Responsive_Design

Letzer Zugriff am 24.03.2026

[CL:Web23] Liew, Zell:

How to build a responsive grid system

Zell Liew

<https://zellwk.com/blog/responsive-grid-system/>

Letzer Zugriff am 24.03.2026

[CL:Web24] Khagwal, Nitish:

Responsive Grid Design: Ultimate Guide

Medium

<https://medium.com/@nitishkmrk/responsive-grid-design-ultimate-guide-7aa41ca7892>

Letzer Zugriff am 24.03.2026

[CL:Web25] W3C:

Media Queries (Working Draft)

W3C

<https://www.w3.org/TR/mediaqueries-3/>

Letzer Zugriff am 24.03.2026

[CL:Web26] Google web.dev:

Media queries

web.dev

<https://web.dev/learn/design/media-queries>

Letzer Zugriff am 24.03.2026

[CL:Web27] Hempenius, Katie:

Serve responsive images

web.dev
<https://web.dev/articles/serve-responsive-images>
Letzer Zugriff am 24.03.2026

[CL:Web28] Mightybytes:
Optimizing Photos Within a Responsive Design
Mightybytes
<https://www.mightybytes.com/insights/optimizing-images-for-responsive-design/>
Letzer Zugriff am 24.03.2026

[CL:Web29] UserWay:
Image ALT Text Best Practices
UserWay
<https://userway.org/blog/image-alt-text/>
Letzer Zugriff am 24.03.2026

[CL:Web30] Google web.dev:
Responsive images
web.dev
<https://web.dev/learn/design/responsive-images>
Letzer Zugriff am 24.03.2026

[CL:Web31] Vanseo Design:
7 Responsive Navigation Patterns
Vanseo Design
<https://vanseodesign.com/web-design/responsive-navigation-patterns/>
Letzer Zugriff am 24.03.2026

[CL:Web32] Rascia, Tania:
Off Canvas Navigation
Tania Rascia
<https://www.taniarascia.com/off-canvas-navigation/>
Letzer Zugriff am 24.03.2026

[CL:Web33] Liew, Zell:
Everything I know about Responsive Web Typography
Zell Liew
<https://zellwk.com/blog/responsive-typography/>
Letzer Zugriff am 24.03.2026

[CL:Web34] Google web.dev:
Responsive and fluid typography with Baseline CSS features
web.dev
<https://web.dev/articles/baseline-in-action-fluid-type>
Letzer Zugriff am 24.03.2026

[CL:Web35] Float UI:

Responsive Typography: Font Size Best Practices

Float UI

<https://floatui.com/blog/responsive-typography-font-size-best-practices>

Letzter Zugriff am 24.03.2026

[CL:Web36] Pimp my Type:

The ideal line length and line height in web design

Pimp my Type

<https://pimpmytype.com/line-length-line-height/>

Letzter Zugriff am 24.03.2026

[CL:Web37] MDN Web Docs:

Using container size and style queries

MDN Web Docs

https://developer.mozilla.org/en-US/docs/Web/CSS/Guides/Containment/Container_size_and_style_queries

Letzter Zugriff am 24.03.2026

[CL:Web38] LePage, Pete; Andrew, Rachel:

Responsives Webdesign – Grundlagen

web.dev

<https://web.dev/articles/responsive-web-design-basics>

Letzter Zugriff am 24.03.2026

[CL:Web39] Flutter API Documentation:

AssetImage class – painting library

Flutter Documentation

<https://api.flutter.dev/flutter/painting/AssetImage-class.html>

Letzter Zugriff am 24.03.2026

[CL:Web40] Schade, Amy:

Responsive Web Design (RWD) and User Experience

Nielsen Norman Group

<https://www.nngroup.com/articles/responsive-web-design-definition/>

Letzter Zugriff am 24.03.2026

	HÖHERE TECHNISCHE BUNDESLEHRANSTALT ST. PÖLTEN	
	Fachrichtung:	Informatik
	Ausbildungsschwerpunkt:	Anlagentechnik

DIPLOMARBEIT

DOKUMENTATION

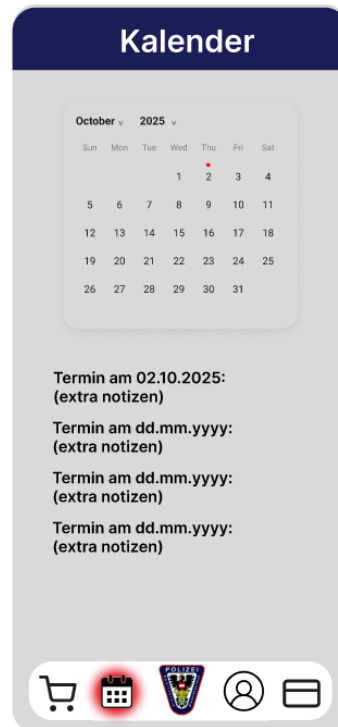
Namen der Verfasser/innen	Barsam Aghajani Rizi Christian Langsteiner Enes Ünlü David Steininger Nadine Pöll
Jahrgang Schuljahr	2025/26
Thema der Diplomarbeit	Konzeption einer Verwaltungsapplikation für den Polizeisportverein
Kooperationspartner	Polizeisportverein Sankt Pölten

Aufgabenstellung	Ziel ist die Entwicklung einer App für den Polizeisportverein NÖ, die den Mitgliedsausweis digital bereitstellt, eine einfache Beitragszahlung ermöglicht und Mitglieder zur eigenständigen Datenverwaltung befähigt. Zusätzlich sollen Kommunikation, Veranstaltungsinfos und Bestellungen zentral über die App erfolgen, um Verwaltung und Service zu modernisieren.
------------------	--

Realisierung	Das Ziel des Projektes konnte nicht vollständig erreicht werden. Die ID Austria Funktion wurde im Rahmen einer Scope-Kürzung gestrichen. Anstonsten wurden alle Funktionalitäten, wie Kalender, Push-Benachrichtig, digitale Zahlungsverwaltung und Mitgliedsverwaltung. Benutzer können die App im App Store herunterladen, sich ein Konto erstellen und die Mitgliedschaft nach Zahlung aktivieren.
--------------	---

Ergebnisse	A) Analyse und prototypische Implementierung der ID Austria als Authentifizierungsmethode sowie Konzeption einer DSGVO-konformen Datenverwaltung in einer mobilen Vereins-App (Aghajani Rizi) B) Untersuchung und Vergleich moderner elektronischer Zahlungstechnologien sowie Integration eines Zahlungssystems in die Vereins-App (Ünlü) C) Analyse von Barrierefreiheit und Inklusion im digitalen Raum mit Fokus auf das österreichische Barrierefreiheitsgesetz sowie Umsetzung in der Vereins-App (Steininger) D) Erarbeitung eines Leitfadens für UI/UX-Design mit Schwerpunkten auf Responsive Design, Farbgestaltung, Typographie und Navigationskonzepten (Langsteiner) E) Analyse und Umsetzung von Qualitätssicherungsmaßnahmen in der Softwareentwicklung mit praktischen Beispielen aus dem Vereins-App-Projekt (Pöll)
------------	---

Typische Grafik, Foto etc.
(mit Erläuterung)



Das Ziel des Projektes konnte nicht vollständig erreicht werden. Die ID Austria Funktion wurde im Rahmen einer Scope-Kürzung gestrichen. Ansonsten wurden alle Funktionalitäten wie Kalender, Push-Benachrichtigungen, digitale Zahlungsverwaltung und Mitgliedsverwaltung erfolgreich implementiert. Benutzer können die App im App Store herunterladen, sich ein Konto erstellen und die Mitgliedschaft nach erfolgter Zahlung aktivieren. Nach erfolgreicher Anmeldung hat der Nutzer Zugriff auf die Kalenderfunktion, über die er bevorstehende Ereignisse und Veranstaltungen des Vereins einsehen kann. Administratoren können Einträge verwalten und Mitglieder per Push-Benachrichtigung über neue Ereignisse informieren.

Teilnahme an Wettbewerben,
Auszeichnungen

keine

Möglichkeiten der
Einsichtnahme in die Arbeit

HTBLuVA St. Pölten Abteilung für Informatik Waldstraße 3, 3100 St. Pölten.

Approbation
(Datum / Unterschrift)

Prüfer/Prüferin

Direktor/Direktorin
Abteilungsvorstand/Abteilungsvorständin

Kapitel	Autor	Titel
1	Projekt Team	Einleitung
2	Barsam Aghajani Rizi	Identitätsmanagement im digitalen Raum
3	Barsam Aghajani Rizi	ID Austria
4	Enes Ünlü	Grundlagen elektronischer Zahlungssysteme
5	Enes Ünlü	Analyse moderner Zahlungstechnologien
6	Enes Ünlü	Projektbezug (Zahlungen)
7	Enes Ünlü	Ausblick von Zahlungen
8	David Steininger	Theoretische Grundlagen zur Inklusion
9	David Steininger	Rechtliche Rahmenbedingungen
10	David Steininger	Herausforderungen und Lösungsansätze
11	David Steininger	Technische Anforderungen und Standards
12	David Steininger	Fallbeispiel: Polizei-Sportverein-App
13	David Steininger	Fazit Barrierefreiheit
14	Christian Langsteiner	Responsive Webdesign
15	Christian Langsteiner	Usability im Webdesign
16	Christian Langsteiner	Umsetzung einer responsiven Website
17	Nadine Pöll	Grundlagen der Qualitätssicherung
18	Nadine Pöll	Qualitätssicherung im Softwareentwicklungsprozess
19	Nadine Pöll	Testmethoden als Kern der Qualitätssicherung
20	Nadine Pöll	Projektbezug mit Qualitätssicherung
21	Barsam Aghajani Rizi	Analyse und Stakeholder
22	Barsam Aghajani Rizi	Architektur und Implementierung
23	Projekt Team	Fazit

KW	Tätigkeit von Barsam Aghajani Rizi	Stunden
39	Recherche zu elektronischen Zahlungssystemen und Authentifizierungsverfahren, Definition der Problemstellung, Erstellung des Inhaltsverzeichnisses	8
40	Literaturrecherche zu Identitätsmanagement und ID Austria, Ausarbeitung der Zielsetzung der Diplomarbeit	7
41	Schreiben Kapitel 2 – Identitätsmanagement: digitale Identität, IAM, SSO	8
42	Schreiben Kapitel 2 – OAuth 2.0: Rollen, Authorization Code Flow	7
43	Schreiben Kapitel 2 – OpenID Connect, JWT, Refresh Token, PKCE	8
44	Abschluss Kapitel 2 – Identitätsmanagement, Überarbeitung und Korrekturen	5
45	Recherche für Kapitel 3 – ID Austria: Was ist ID Austria, Authentifizierungsfaktoren	6
46	Schreiben Kapitel 3 – eIDAS Authentifizierungslevel, Signaturstufen EES/AES/QES	7
47	Schreiben Kapitel 3 – SAML2 vs. OIDC, Registrierung als Service Provider	8
48	Schreiben Kapitel 3 – Anmeldung mit ID Austria via OIDC, Vorteile im Vereinskontext	7
49	Abschluss Kapitel 3 – ID Austria, Überarbeitung und Korrekturen	5
50	Recherche für Kapitel 4 – Analyse: Zielgruppen, Stakeholder, Use Cases	6
51	Schreiben Kapitel 4 – Use Cases 1–3: Registrierung, Anmeldung, Digitale Signatur mit Mockups	8
2	Schreiben Kapitel 4 – Use Cases 4–5: Kalender, Zahlungsabwicklung, Sicherheitsanforderungen	7
3	Schreiben Kapitel 4 – DSGVO-Anforderungen, Datenschutz, Soft Delete	6
4	Schreiben Kapitel 5 – Systemarchitektur, Datenbankmodell, ER-Diagramm Erstellung und Korrektur	8

KW	Tätigkeit von Barsam Aghajani Rizi	Stunden
5	Schreiben Kapitel 5 – Authentifizierung: JWT-Service, SecurityConfig, Passwort-Hashing mit Salt	8
7	Schreiben Kapitel 5 – Rollenbasierter Zugriff, Admin-Flags, Fallbeispiel Mitgliedsausweis	7
8	Schreiben Kapitel 5 – Geplante ID Austria Integration, Sicherheitsvorteile	6
9	Schreiben Kapitel 1 – Einleitung: Problemstellung, Zielsetzung, Abgrenzung, Methodisches Vorgehen	6
10	Schreiben Kapitel 6 – Fazit und Ausblick, Zusammenfassung der Ergebnisse	5
11	Finales Lektorat und Überarbeitung der gesamten Arbeit, Korrekturen und Formatierung	5
12	Fertigstellung des Literaturverzeichnisses, Abbildungsverzeichnis, Einreichung der Diplomarbeit	4
Gesamt		152

KW	Tätigkeit von Enes Ünlü	Stunden
39	Recherche zu elektronischen Zahlungssystemen und Zahlungstechnologien, Definition der Problemstellung, Erstellung des Inhaltsverzeichnisses	10
40	Literaturrecherche zu Grundlagen elektronischer Zahlungssysteme, Ausarbeitung der Zielsetzung der Diplomarbeit	8
41	Schreiben Kapitel „Grundlagen elektronischer Zahlungssysteme“ – Abschnitte 1.1 Abgrenzung und 1.2 Historische Entwicklung	8
42	Schreiben Kapitel „Grundlagen“ – 1.3 Zentrale Anforderungen (Sicherheit, Benutzerfreundlichkeit, Kosten)	6
43	Schreiben Kapitel „Grundlagen“ – 1.4 Rechtliche Rahmenbedingungen (PSD2, AML, DSGVO)	7
44	Abschluss Kapitel „Grundlagen elektronischer Zahlungssysteme“	3
45	Recherche für Kapitel „Analyse moderner Zahlungstechnologien“, Einstieg Klassische Online-Bezahlsysteme	6
46	Schreiben Kapitel 2.1 „Klassische Online-Bezahlsysteme“ – Kreditkarten, PCI-DSS-Standard, 3D Secure	8
47	Schreiben Kapitel 2.1 – Lastschriftverfahren (SEPA) und Sofortüberweisungen	7
48	Abschluss Kapitel 2.1 – Vor- und Nachteile klassischer Online-Bezahlsysteme	4
49	Recherche für Kapitel 2.2 „Mobile Wallets & Contactless Payment“, Einstieg NFC-Technologie	6
50	Schreiben Kapitel 2.2 – NFC, Tokenisierung und Host Card Emulation (HCE)	8
51	Schreiben Kapitel 2.2 – Anbieter und Ökosysteme: Apple Pay und Google Pay	6
2	Schreiben Kapitel 2.2 – Samsung Pay, Sicherheitsarchitektur und Biometrie	7

KW	Tätigkeit von Enes Ünlü	Stunden
3	Schreiben Kapitel 2.3 „Kryptowährungen und Blockchain-basierte Systeme“ – Blockchain-Grundlagen, Dezentralisierung, Wallets	8
4	Schreiben Kapitel 2.3 – Beispiel Bitcoin, Proof of Work vs. Proof of Stake, Smart Contracts	7
5	Abschluss Kapitel „Analyse moderner Zahlungstechnologien“, Überarbeitung und Korrekturen	6
7	Recherche und Schreiben Kapitel 3 „Projektbezug“ – Stripe-Integration, Grundlagen und Architektur	6
8	Schreiben Kapitel 3 – Zahlungsintegration im Frontend (Flutter/Stripe SDK) und Backend (Spring Boot)	8
9	Schreiben Kapitel 3.4 Testing und Kapitel 4 „Ausblick von Zahlungen“, aktuelle Trends	6
10	Finales Lektorat und Überarbeitung der gesamten Arbeit, Korrekturen und Formatierung	5
11	Fertigstellung des Literaturverzeichnisses und Anhangs, Abbildungs- und Tabellenverzeichnis	5
12	Letzte Korrekturen und Feinschliff, Schreiben der Danksagung, Einreichung der Diplomarbeit	5
Gesamt		150

KW	Tätigkeit von David Steininger	Stunden
34	Schreiben von Inhaltsverzeichnis und Quellen suchen	2
35	Schreiben von Inhaltsverzeichnis und Quellen suchen	2
36	Erstellung von Inhaltsverzeichnis, Vorbereitung	4
39	Recherche/Vorbereitung zu Kapitel 1 und allgemeinen Thematik	6
40	Schreiben Kapitel 1.1 Problemstellung und Relevanz der Thematik, 1.2 Zielsetzung und Forschungsfragen	8
41	Schreiben 1.3 Aufbau der Arbeit, 1.4 Methodisches Vorgehen	5
42	Schreiben Kapitel 2.1 Begriffsklärung: Behinderung, Beeinträchtigung, Inklusion	6
44	Schreiben Kapitel 2.2 Digitale Barrierefreiheit: Definition und Dimensionen, 2.3 Nutzergruppen mit besonderen Bedürfnissen	9
45	Schreiben 2.3 Nutzergruppen mit besonderen Bedürfnissen	2
48	Recherche Rechtliche Rahmenbedingungen Österreich/Europa, Überarbeitung Kapitel 2	6
51	Schreiben Kapitel 3.1 Europäische Richtlinien (EU Accessibility Act, Web Accessibility Directive), 3.2 Österreichisches Bundes- Behindertengleichstellungsgesetz (BGStG)	8
1	Schreiben Kapitel 3.3 Barrierefreiheitsgesetz Österreich (Barrierefreiheitsgesetz 2025)	3
2	Kapitel 3.4 Web-Zugänglichkeitsgesetz-Gesetz, 3.5 Vergleich Internationale Standards, 3.6 Analyse Chancen , Herausforderungen und offene Fragen der Umsetzung	9
3	Kapitel 3.6 (Analyse: Chancen, Herausforderungen und offene Fragen der Umsetzung)	4

KW	Tätigkeit von David Steininger	Stunden
6	Planung/Recherche Kapitel 4, schreiben Kapitel Kapitel 4.1 Marktüberblick, 4.2 Typische Probleme in der Praxis, 4.3 Kosten-Nutzen-Analyse barrierefreier Entwicklung	15
7	Schreiben Kapitel 4.4 Integration von Inklusion in Entwicklungsprozesse, 4.5 Best Practices und innovative Ansätze	7
9	Kapitel 5.1 W3C und WCAG-Richtlinien – Überblick und Ebenen (A, AA, AAA), 5.2 Technische Hilfsmittel (Screenreader, Braillezeilen, Sprachsteuerung, alternative Eingabegeräte)	9
9	Kapitel 5.3 Code-Beispiele, 5.4 Barrierefreie Bilder, Videos und Dokumente (Alt-Texte, Untertitel, Audiodeskriptionen)	10
10	Kapitel 6 Brainstorming, Schreiben Kapitel 6 Fallbeispiel: Polizei-Sportverein-App	7
11	Schreiben Kapitel 6 Fallbeispiel	13
12	Kapitel 7, Verbessern aller Kapitel	12
13	Verbessern, Layout, Finalisierung, Danksagung	10
Summe		157

KW	Tätigkeit von Nadine Pöll	Stunden
35	Erstellung Inhaltsverzeichnis und Strukturplanung	5
39	Recherche zu Qualitätssicherung und Softwarequalität (Kapitel 1)	6
40	Schreiben Kapitel 1: Einleitung zur Qualitätssicherung	9
41	Recherche ISO/IEC 25010 und Grundlagen (Kapitel 2)	8
42	Schreiben Kapitel 2.1–2.2 (Qualität, QS vs QM)	9
43	Schreiben Kapitel 2.3–2.4 (Qualität vs Quantität, Dimensionen)	9
45	Überarbeitung Kapitel 1–2 und Ergänzungen	5
48	Recherche SDLC und Qualität im Prozess (Kapitel 3)	8
50	Schreiben Kapitel 3.1–3.2 (Rolle QS, Qualitätskriterien)	10
1	Schreiben Kapitel 3.2 (Code Reviews, CI/CD, Versionierung)	11
2	Schreiben Kapitel 3.3–3.4 (Verbesserung, Ursachenanalyse)	9
5	Recherche Testmethoden (Kapitel 4)	6
6	Schreiben Kapitel 4.1–4.2 (Verifikation, Testarten)	10
7	Schreiben Kapitel 4.3 (manuell vs automatisiert)	7
9	Schreiben Kapitel 5.1 (Teststrategie, Dokumentation)	7
11	Schreiben Kapitel 5.2 (Backend Tests, CI/CD Integration)	9
12	Gesamtüberarbeitung aller Kapitel	10
13	Korrekturlesen, sprachliche Verbesserung	6
14	Finalisierung, Layout, Danksagung	7
Summe		151

KW	Tätigkeit von Christian Langsteiner	Stunden
45	Recherche Responsive Webdesign	7
45	Schreiben Kapitel Responsive Webdesign	4
47	Recherche und Schreiben Webdesign-Workflow	3
47	Recherche und Schreiben Unterkapitel Graceful Degradation, Progressive Enhancement und Mobile First	6
47	Abschluss Kapitel – Responsive Webdesign	5
50	Recherche Usability im Webdesign	6
50	Recherche und Schreiben Unterkapitel – Millersche Zahl und Hicksches Gesetz	4
51	Recherche und Schreiben Unterkapitel – DIN EN ISO 9241 und DIN 1450	5
3	Abschluss Kapitel – Usability im Webdesign	7
3	Recherche Media Queries	10
3	Recherche Grids	8
5	Codebeispiele für Media Queries und Grids erstellt	13
5	Schreiben Unterkapitel – Media Queries	5
6	Schreiben Unterkapitel – Grids	5
6	Recherche Responsive Bilder	5
7	Schreiben Unterkapitel – Responsive Bilder	4
7	Recherche und Schreiben Unterkapitel – Navigationstypen	6
7	Recherche und Schreiben Unterkapitel – Typografie	4
8	Flutter Code Beispiele schreiben und einbauen	6
9	Abschluss Kapitel – Umsetzung einer responsiven Website	8
10	Schreiben Kapitel – Einleitung	2
12	Schreiben Fazit	3
12	Letzte Änderungen, Quellen checken, Mergen	20
Gesamt		146